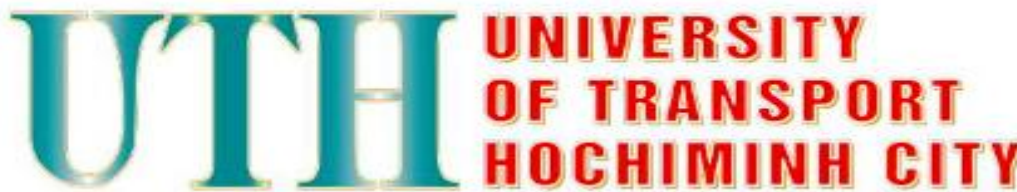


BỘ XÂY DỰNG
TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI TP.HCM
VIỆN ĐÀO TẠO CHẤT LƯỢNG CAO



BÁO CÁO
ĐẶC TẢ YÊU CẦU PHẦN MỀM (SRS)

Tên đề tài:

HỆ THỐNG THƯƠNG MẠI ĐIỆN TỬ TECHVIE

Mã dự án: TECHVIE-EC-2026

Phiên bản: 1.0.0 (Final Production Spec)

Ngày phát hành: 26/07/2026

Thực hiện bởi: Nhóm 5

Danh sách thành viên	MSSV
Trần Trung Nam	087205007981
Trần Xuân Phát	040205008154
Nguyễn Hữu Phương	077205000760
Trương Quang Huy	079205013084

CHƯƠNG 1: GIỚI THIỆU TỔNG QUAN (INTRODUCTION)

1.1. Mục đích tài liệu

Tài liệu Đặc tả Yêu cầu Phần mềm (Software Requirements Specification – SRS) này mô tả các yêu cầu nghiệp vụ, yêu cầu chức năng, yêu cầu phi chức năng, yêu cầu giao diện, các ràng buộc và giả định của hệ thống Website Thương mại Điện tử Phụ kiện Công nghệ TechVie. Tài liệu là cơ sở để phân tích, thiết kế, phát triển, kiểm thử và nghiệm thu hệ thống.

Tài liệu phục vụ làm căn cứ chính thức cho:

- Đội ngũ Phát triển Phần mềm (Developers): Hiểu và triển khai các chức năng theo yêu cầu đã được đặc tả.
- Đội ngũ Quản lý Dự án và Kiểm thử (Project Managers / QA): Theo dõi phạm vi dự án, xây dựng kế hoạch kiểm thử và nghiệm thu hệ thống.
- Khách hàng/ Ban Quản trị: Hiểu phạm vi chức năng, các yêu cầu của hệ thống và làm căn cứ đánh giá mức độ đáp ứng của sản phẩm.

1.2. Phạm vi hệ thống

Hệ thống TechVie là nền tảng thương mại điện tử (Business-to-Consumer – B2C) chuyên cung cấp các phụ kiện công nghệ và các sản phẩm tùy biến theo nhu cầu khách hàng. Hệ thống hỗ trợ người dùng trong quá trình tìm kiếm, lựa chọn, mua sắm và quản lý đơn hàng trực tuyến, đồng thời cung cấp công cụ quản trị phục vụ việc vận hành và quản lý toàn bộ hoạt động kinh doanh. Phạm vi của hệ thống bao gồm 3 phân hệ chính:

- Phân hệ Khách hàng (Storefront - B2C): Cho phép khách hàng xem và tìm kiếm sản phẩm, lọc sản phẩm theo nhiều tiêu chí, quản lý giỏ hàng, đặt hàng trực tuyến, áp dụng mã giảm giá, lựa chọn phương thức thanh toán, quản lý thông tin cá nhân, theo dõi trạng thái đơn hàng, đánh giá các sản phẩm đã mua và đăng ký nhận thông tin khuyến mãi.
- Phân hệ Quản trị (Admin Dashboard - Operations): Cho phép quản trị viên quản lý sản phẩm, danh mục, tồn kho, đơn hàng, mã giảm giá, đánh giá của khách hàng, thông tin người dùng, thống kê hoạt động kinh doanh và xử lý các yêu cầu liên hệ từ khách hàng.
- Phân hệ Tích hợp Máy chủ & Hạ tầng Cloud (Backend & Cloud Services): Cung cấp các chức năng xử lý nghiệp vụ, quản lý dữ liệu, xác thực người

dùng, lưu trữ hình ảnh, gửi thư điện tử và tích hợp với các dịch vụ bên ngoài (thanh toán, OAuth Google, Nodemailer SMTP).

1.3. Định nghĩa và Thuật ngữ viết tắt

Ký hiệu / Thuật ngữ	Chữ viết đầy đủ	Giải thích nghĩa
API	Application Programming Interface	Giao diện lập trình ứng dụng giao tiếp giữa Client và Server
B2C	Business-to-Consumer	Mô hình kinh doanh giữa doanh nghiệp trực tiếp tới người tiêu dùng
COD	Cash On Delivery	Phương thức thanh toán bằng tiền mặt khi nhận hàng
IPN	Instant Payment Notification	Thông báo thanh toán tức thì từ cổng thanh toán / ngân hàng
JWT	JSON Web Token	Token dạng JSON được ký số, dùng để xác thực người dùng và truyền thông tin định danh, vai trò trong phiên đăng nhập.
RBAC	Role-Based Access Control	Cơ chế kiểm soát truy cập dựa trên vai trò người dùng (User, Employee, Admin).
SRS	Software Requirements Specification	Tài liệu đặc tả yêu cầu phần mềm chuẩn IEEE
VIP Status	Premium Member Status	Trạng thái thành viên thân thiết nhận ưu đãi và bảo vệ đặc quyền

Ký hiệu / Thuật ngữ	Chữ viết đầy đủ	Giải thích nghĩa
Soft Delete	Logical Deletion	Cơ chế xóa ảo (đánh dấu isDeleted: true) để bảo toàn dữ liệu lịch sử

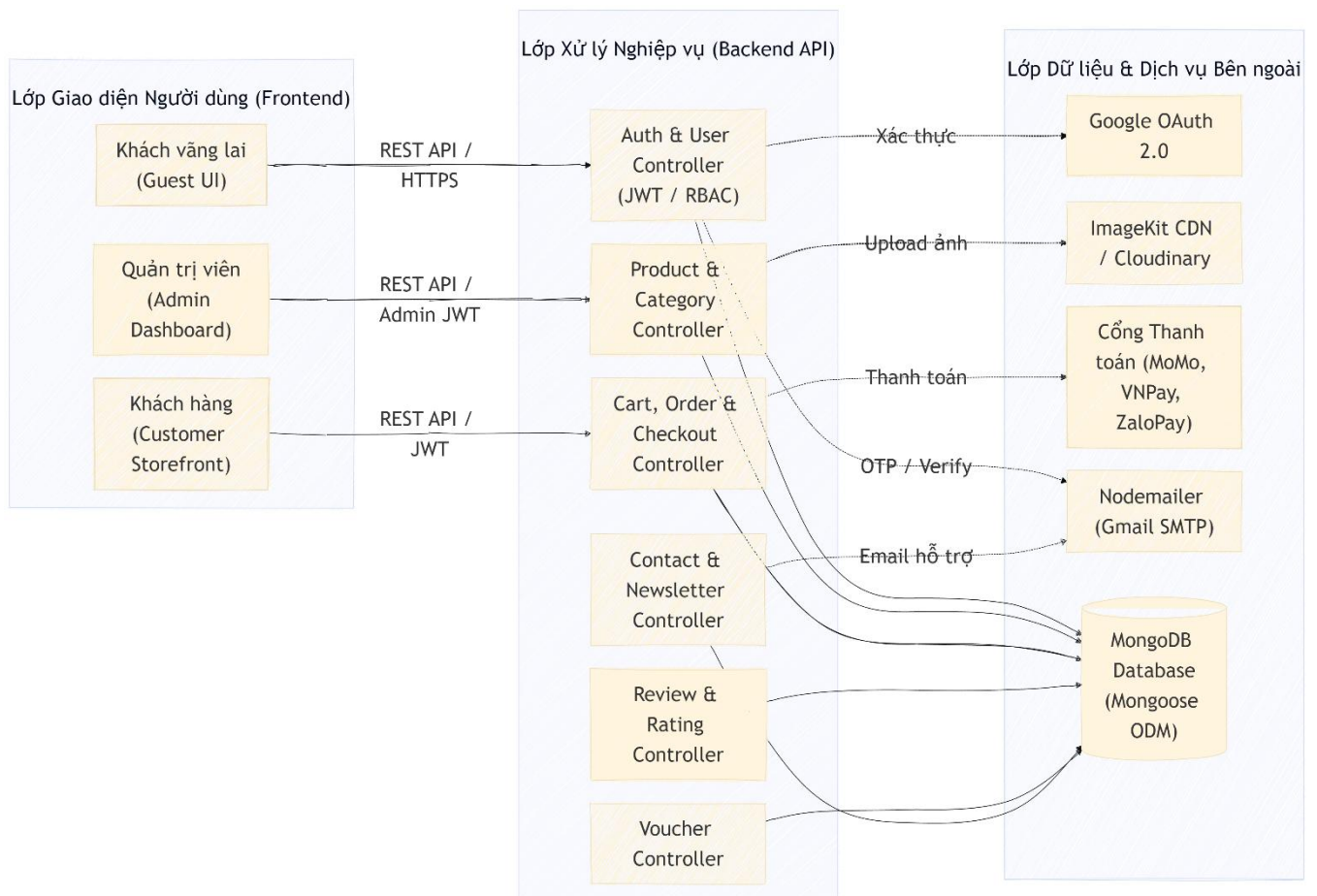
1.4. Tài liệu tham khảo

- (1) IEEE Std 830 - 1998: IEEE Recommended Practice for Software Requirements Specifications.
- (2) Tiêu chuẩn Quốc gia TCVN 11814:2017 về Quy trình Phát triển Phần mềm.
- (3) Bộ Luật Thương mại Điện tử & Nghị định 52/2013/NĐ-CP, Nghị định 85/2021/NĐ-CP của Chính phủ về Quản lý hoạt động TMĐT.
- (4) Báo cáo Học phần Thương mại Điện tử TechVie - Nhóm 5 (ĐH GTVT TP.HCM, Tháng 7/2026).

CHƯƠNG 2: MÔ TẢ TỔNG QUAN HỆ THỐNG (OVERALL DESCRIPTION)

2.1. Kiến trúc tổng thể hệ thống (System Architecture)

Hệ thống TechVie được thiết kế theo kiến trúc Phân lớp Hiện đại (Decoupled Client-Server Architecture). Hệ thống TechVie được xây dựng theo kiến trúc Client–Server tách biệt giữa Frontend và Backend. Frontend chịu trách nhiệm hiển thị giao diện và xử lý tương tác với người dùng, trong khi Backend cung cấp các RESTful API để xử lý nghiệp vụ, xác thực, phân quyền và truy xuất dữ liệu. Dữ liệu của hệ thống được lưu trữ trên MongoDB thông qua Mongoose ODM. Backend đồng thời tích hợp các dịch vụ bên ngoài như ImageKit, Cloudinary, Google OAuth 2.0, Nodemailer SMTP và các dịch vụ thanh toán.



Hình 1. Kiến trúc tổng thể hệ thống TechVie

2.2. Phân loại tác nhân người dùng (User Classes & Actors)

Hệ thống phục vụ 4 nhóm tác nhân chính:

(1) Khách vắng lai (Guest / Anonymous User):

- Truy cập trang chủ, xem danh sách sản phẩm, chi tiết sản phẩm, bài viết tin tức và các chính sách của thương hiệu.
- Tìm kiếm và lọc sản phẩm theo các tiêu chí được hệ thống hỗ trợ; hệ thống có thể ghi nhận lịch sử tìm kiếm theo địa chỉ IP.
- Thêm sản phẩm vào giỏ hàng và quản lý giỏ hàng trên thiết bị người dùng.
- Thực hiện đặt hàng dưới hình thức Guest Checkout mà không bắt buộc đăng nhập tài khoản.
- Đăng ký tài khoản mới, đăng nhập bằng tài khoản TechVie hoặc Google.
- Gửi yêu cầu liên hệ và đăng ký nhận bản tin Newsletter.

(2) Khách hàng đã đăng ký (Registered Customer - Role: user):

- Thực hiện toàn bộ các chức năng của Khách vắng lai.
- Đặt hàng trực tuyến và sử dụng thông tin cá nhân đã lưu để hỗ trợ quá trình Checkout.
- Quản lý hồ sơ cá nhân, số điện thoại, địa chỉ và thay đổi mật khẩu.
- Xác thực địa chỉ email thông qua liên kết được gửi qua hệ thống email.
- Theo dõi lịch sử và trạng thái các đơn hàng cá nhân.
- Tra cứu danh sách thiết bị/sản phẩm đã mua và thông tin bảo hành tương ứng.
- Gửi đánh giá và nhận xét đối với sản phẩm đủ điều kiện Verified Purchase.
- Được quản lý trạng thái thành viên VIP thông qua thuộc tính vipStatus.

(3) Nhân viên (Employee – Role: employee):

- Hệ thống có hỗ trợ vai trò employee trong mô hình dữ liệu tài khoản và chức năng quản lý phân quyền.
- Tài khoản Employee có thể đăng nhập bằng cơ chế xác thực chung của hệ thống và sử dụng các chức năng người dùng phù hợp với trạng thái tài khoản.
- Trong phiên bản hiện tại, các API quản trị đơn hàng, quản lý liên hệ và giao diện /admin/* vẫn được giới hạn cho vai trò admin.
- Hệ thống chưa triển khai giao diện Dashboard hoặc middleware phân quyền vận hành riêng cho Employee.

- Admin có thể cấp hoặc thay đổi vai trò tài khoản thành user, employee hoặc admin.

(4) Quản trị viên Hệ thống (System Administrator - Role: admin):

- Đăng nhập quyền Admin bảo mật cao.
- Truy cập Bảng điều khiển (Admin Dashboard) xem tổng quan doanh thu, số lượng đơn hàng, người dùng.
- Quản lý Sản phẩm (CRUD, upload ảnh ImageKit với Cloudinary dự phòng, khôi phục Soft Delete).
- Quản lý Danh mục sản phẩm (CRUD & Tự động seed danh mục mặc định).
- Quản lý Đơn hàng: Cập nhật trạng thái xử lý (processing, shipping, success, cancelled) và trạng thái thanh toán (pending, paid, failed, cancelled).
- Quản lý Voucher khuyến mãi: Tạo mã, thiết lập giá trị giảm, kích hoạt/vô hiệu hóa.
- Quản lý Đánh giá: Phản hồi đánh giá của khách hàng, ẩn/hiện đánh giá vi phạm, xóa/khôi phục đánh giá.
- Quản lý Người dùng: Thay đổi vai trò giữa user, employee và admin; thay đổi trạng thái VIP; khóa/mở khóa tài khoản; xóa mềm và khôi phục tài khoản.
- Quản lý Hòm thư Liên hệ: Xem ý kiến đóng góp và gửi email trả lời trực tiếp qua hệ thống SMTP.

2.3. Môi trường vận hành và Công nghệ sử dụng

2.3.1. Backend Environment

Hệ thống sử dụng kiến trúc RESTful API chạy trên nền tảng Node.js với framework Express.js để xử lý các yêu cầu từ phía người dùng. Dữ liệu được lưu trữ trên MongoDB và quản lý thông qua Mongoose ODM. Hệ thống sử dụng JSON Web Token (JWT) để xác thực và phân quyền người dùng, kết hợp với bcryptjs để băm mật khẩu. Hệ thống ưu tiên lưu trữ hình ảnh qua ImageKit và sử dụng Cloudinary làm dịch vụ dự phòng.

2.3.2. Frontend Environment

Giao diện người dùng được phát triển theo mô hình Single Page Application (SPA) sử dụng React và TypeScript, được xây dựng với Vite và Tailwind CSS.

Hệ thống áp dụng Responsive Web Design nhằm hỗ trợ nhiều kích thước màn hình khác nhau. Các thành phần chuyển động, biểu tượng và thông báo giao diện được sử dụng nhằm nâng cao trải nghiệm người dùng và hỗ trợ các chức năng quản trị.

2.3.3. External Services

Các dịch vụ bên ngoài bao gồm ImageKit, Cloudinary, Nodemailer SMTP, Google OAuth 2.0 và các cơ chế thanh toán Sandbox/Demo. Hệ thống ưu tiên sử dụng ImageKit để lưu trữ hình ảnh và sử dụng Cloudinary làm dịch vụ dự phòng. Backend hiện hỗ trợ các phương thức cod, card_online, bank_transfer, momo và zalopay trong mô hình lưu trữ đơn hàng. SePay IPN được triển khai để đối soát thanh toán chuyển khoản ngân hàng.

2.4. Ràng buộc thiết kế và triển khai

- Hệ thống sử dụng mô hình kiến trúc Client–Server, trong đó Frontend và Backend giao tiếp thông qua RESTful API.
- Các chức năng yêu cầu quyền hạn phải thực hiện xác thực JWT và kiểm tra vai trò người dùng; ngoại lệ hiện tại là một số API quản lý Voucher chưa áp dụng middleware phân quyền, như mô tả tại FR-VOCH-02.
- Hệ thống cần duy trì tính toàn vẹn và nhất quán của dữ liệu trong quá trình xử lý đơn hàng; tuy nhiên phiên bản hiện tại chưa tự động tính lại finalTotal và chưa tự động giảm/hoàn tồn kho khi tạo hoặc hủy Order.
- Hệ thống phải hỗ trợ hoạt động trên các trình duyệt web hiện đại và giao diện phải đáp ứng trên máy tính, máy tính bảng và điện thoại.
- Các dịch vụ bên ngoài như lưu trữ hình ảnh, gửi email, xác thực và thanh toán được tích hợp thông qua API của nhà cung cấp.

2.5. Giả định và Phụ thuộc

- Máy chủ ứng dụng và cơ sở dữ liệu luôn sẵn sàng để tiếp nhận và xử lý yêu cầu.
- Dịch vụ lưu trữ hình ảnh hoạt động ổn định để cung cấp hình ảnh sản phẩm và các tài nguyên đa phương tiện.
- Dịch vụ gửi email luôn khả dụng để phục vụ chức năng xác thực tài khoản và khôi phục mật khẩu.
- Các dịch vụ xác thực và thanh toán của bên thứ ba phản hồi đúng theo giao thức và định dạng dữ liệu đã công bố.

- Người dùng sử dụng trình duyệt web hiện đại có hỗ trợ JavaScript và kết nối Internet ổn định.

CHƯƠNG 3: YÊU CẦU CHỨC NĂNG CHI TIẾT (DETAILED FUNCTIONAL REQUIREMENTS)

3.1. Phân hệ Xác thực & Quản lý Tài khoản (Auth & User Management)



Hình 2. Sơ đồ chức năng phân hệ Xác thực và Người dùng

3.1.1. FR-AUTH-01: Đăng ký Tài khoản (User Registration)

Mô tả: Cho phép người dùng tạo tài khoản mới bằng tên người dùng, email và mật khẩu.

Luồng xử lý:

- Người dùng nhập họ tên/tên hiển thị, email, mật khẩu và xác nhận mật khẩu trên giao diện đăng ký.
- Frontend kiểm tra các trường bắt buộc, mật khẩu tối thiểu 6 ký tự, mật khẩu xác nhận phải trùng khớp và người dùng phải đồng ý với Điều khoản dịch vụ và Chính sách bảo mật.
- Frontend có thể gọi GET /api/auth/check-email?email=<email> để kiểm tra email trước khi gửi yêu cầu đăng ký.
- Backend tiếp nhận username, email, password; đồng thời hỗ trợ full_name hoặc fullName như tên người dùng nhằm tương thích dữ liệu.
- Backend kiểm tra các trường bắt buộc và kiểm tra định dạng email.

- Nếu email đã thuộc một tài khoản đang hoạt động và đã được xác thực email, hệ thống từ chối đăng ký với mã HTTP 409.
- Nếu email thuộc một tài khoản chưa xác thực (isEmailVerified: false), hệ thống xóa bản ghi chưa xác thực cũ và cho phép người dùng đăng ký lại bằng email đó.
- Hệ thống kiểm tra username không được trùng với tài khoản đang tồn tại.
- Mật khẩu được băm bằng bcryptjs với salt round = 10 trước khi lưu.
- Tài khoản mới được tạo với các giá trị mặc định role: "user", vipStatus: "Normal", status: "active", auth_provider: "credentials", isEmailVerified: false và isDeleted: false.
- Sau khi đăng ký thành công, Backend trả về thông tin tài khoản và JWT Token chứa id, email, role; JWT có thời hạn 24 giờ.
- Việc gửi email xác thực được thực hiện riêng thông qua chức năng FR-AUTH-05.

Endpoints:

- POST /api/auth/register
- GET /api/auth/check-email

Quyền truy cập: Public.

3.1.2. FR-AUTH-02: Đăng nhập Hệ thống (User Login)

Mô tả: Cho phép người dùng đăng nhập bằng Email hoặc Username kết hợp với mật khẩu.

Luồng xử lý:

- Người dùng cung cấp thông tin định danh và mật khẩu.
- Backend tìm tài khoản theo email hoặc username.
- Nếu không tìm thấy tài khoản hoặc mật khẩu không chính xác, hệ thống từ chối đăng nhập.
- Tài khoản có isDeleted: true hoặc status: "blocked" không được phép đăng nhập.

- Nếu tài khoản có auth_provider: "google", hệ thống từ chối đăng nhập bằng mật khẩu truyền thống và yêu cầu sử dụng Google OAuth.
- Backend sử dụng bcryptjs để so sánh mật khẩu với giá trị đã băm trong cơ sở dữ liệu.
- Khi đăng nhập thành công, Backend phát hành JWT Token chứa id, email, role với thời hạn 24 giờ.

Endpoint: POST /api/auth/login.

Quyền truy cập: Public.

3.1.3. FR-AUTH-03: Đăng nhập bằng Google (Google OAuth 2.0 Integration)

Mô tả: Cho phép người dùng đăng nhập hoặc tạo tài khoản TechVie thông qua tài khoản Google.

Luồng xử lý:

- Endpoint GET /api/auth/google sinh một giá trị state, lưu giá trị này trong cookie oauth_state có thời hạn 5 phút và tạo URL điều hướng tới Google Consent Screen.
- Sau khi người dùng chấp thuận, Google chuyển người dùng về GET /api/auth/google/callback cùng Authorization Code.
- Backend yêu cầu phải có tham số code, sau đó trao đổi Authorization Code để lấy Access Token và truy vấn thông tin hồ sơ Google.
- Thông tin được sử dụng gồm Google ID (sub), email, tên và ảnh đại diện.
- Nếu tài khoản theo email đã tồn tại và có status: "blocked", hệ thống từ chối đăng nhập.
- Nếu email đã tồn tại nhưng chưa liên kết Google ID, hệ thống cập nhật google_id, chuyển auth_provider thành "google" và đặt isEmailVerified: true.

- Nếu email chưa tồn tại, hệ thống tạo tài khoản mới với role: "user", vipStatus: "Normal", status: "active", auth_provider: "google" và isEmailVerified: true.
- Sau khi xác thực Google thành công, Backend tạo JWT Token có thời hạn 24 giờ, lưu token trong cookie phiên và chuyển người dùng về Frontend kèm token đăng nhập.

Endpoints:

- GET /api/auth/google
- GET /api/auth/google/callback

Quyền truy cập: Public.

3.1.4. FR-AUTH-04: Quên Mật khẩu & Đặt lại Mật khẩu (Forgot & Reset Password)

Mô tả: Cho phép tài khoản sử dụng phương thức xác thực bằng Email/Mật khẩu khôi phục mật khẩu thông qua email.

Luồng Quên mật khẩu:

- Người dùng gửi email tới POST /api/auth/forgot-password.
- Nếu email không tồn tại, hệ thống vẫn trả phản hồi thành công chung nhằm hạn chế việc dò tìm tài khoản đã đăng ký.
- Nếu tài khoản có auth_provider: "google", hệ thống không thực hiện reset password và yêu cầu người dùng đăng nhập bằng Google.
- Nếu tài khoản đang có Reset Token, hệ thống kiểm tra thời gian kể từ lần yêu cầu gần nhất.
- Khoảng thời gian tối thiểu giữa hai yêu cầu gửi lại email là 60 giây. Yêu cầu thực hiện trước 60 giây bị từ chối với HTTP 429.
- Backend tạo token ngẫu nhiên 32 byte, biểu diễn dưới dạng chuỗi hex 64 ký tự.
- Token gốc được sử dụng trong liên kết gửi cho người dùng; Backend lưu bản băm SHA-256 vào resetPasswordToken.
- resetPasswordExpire được thiết lập với thời hạn 15 phút.

- Hệ thống gửi liên kết đặt lại mật khẩu thông qua Nodemailer SMTP.

Luồng Đặt lại mật khẩu:

- Người dùng gửi mật khẩu mới tới POST /api/auth/reset-password/:token.
- Mật khẩu mới phải có tối thiểu 6 ký tự.
- Backend băm token nhận được bằng SHA-256 và tìm tài khoản có resetPasswordToken tương ứng với resetPasswordExpire > thời điểm hiện tại.
- Token không hợp lệ hoặc đã hết 15 phút bị từ chối.
- Khi token hợp lệ, mật khẩu mới được băm bằng bcryptjs và cập nhật vào cơ sở dữ liệu.
- Sau khi đặt lại thành công, resetPasswordToken và resetPasswordExpire được xóa.

Endpoints:

- POST /api/auth/forgot-password
- POST /api/auth/reset-password/:token

Quyền truy cập: Public.

3.1.5. FR-AUTH-05: Xác thực Email (Email Verification)

Mô tả: Cho phép người dùng đã đăng nhập xác minh quyền sở hữu địa chỉ email của tài khoản.

Luồng gửi email xác thực:

- Người dùng đã đăng nhập gửi yêu cầu tới POST /api/auth/send-verification-email.
- Nếu tài khoản đã có isEmailVerified: true, hệ thống từ chối yêu cầu gửi lại email xác thực.
- Hệ thống áp dụng thời gian chờ tối thiểu 60 giây giữa các lần yêu cầu gửi email xác thực.

- Backend sinh Verification Token ngẫu nhiên 32 byte và lưu bản băm SHA-256 vào emailVerificationToken.
- emailVerificationExpire có thời hạn 24 giờ.
- Token gốc được gửi tới email người dùng dưới dạng liên kết xác thực thông qua Nodemailer SMTP.

Luồng xác nhận:

- Người dùng truy cập GET /api/auth/verify-email?token=<token>.
- Backend băm token nhận được bằng SHA-256 và tìm tài khoản có emailVerificationToken tương ứng còn hiệu lực.
- Nếu token không tồn tại hoặc đã hết hạn, hệ thống từ chối xác thực.
- Nếu token hợp lệ, hệ thống cập nhật isEmailVerified: true, đồng thời xóa emailVerificationToken và emailVerificationExpire.
- Sau khi xác thực thành công, Backend trả redirect HTTP 302 tới /account?verified=true trên Frontend.

Endpoints:

- POST /api/auth/send-verification-email – Logged In.
- GET /api/auth/verify-email – Public.

Kết quả: isEmailVerified = true.

3.1.6. FR-AUTH-06: Quản lý Hồ sơ & Đổi Mật khẩu (Profile & Password Change)

Mô tả: Cho phép người dùng đã đăng nhập xem, cập nhật hồ sơ cá nhân và thay đổi mật khẩu.

Chức năng hồ sơ:

- GET /api/auth/profile: lấy thông tin tài khoản hiện tại.
- PUT /api/auth/profile: cập nhật tên hiển thị, số điện thoại và địa chỉ.
- Backend nhận trường username; đồng thời hỗ trợ trường name để tương thích với Frontend.

- Số điện thoại, nếu được cung cấp, phải phù hợp định dạng số điện thoại Việt Nam được hệ thống hỗ trợ: bắt đầu bằng 0, 84 hoặc +84, tiếp theo là đầu số 3, 5, 7, 8 hoặc 9 và phần số thuê bao tương ứng.

Đổi mật khẩu:

- POST /api/auth/change-password.
- Người dùng phải cung cấp currentPassword và newPassword.
- Backend kiểm tra currentPassword bằng bcryptjs.
- Nếu mật khẩu hiện tại không chính xác, hệ thống từ chối cập nhật.
- Nếu hợp lệ, newPassword được băm bằng bcryptjs trước khi lưu.
- Tài khoản đăng nhập bằng Google không sử dụng giao diện thay đổi mật khẩu truyền thống trên Frontend.

Quyền truy cập: JWT Logged In.

3.1.7. FR-AUTH-07: Tra cứu Thiết bị đã mua & Thông tin Bảo hành

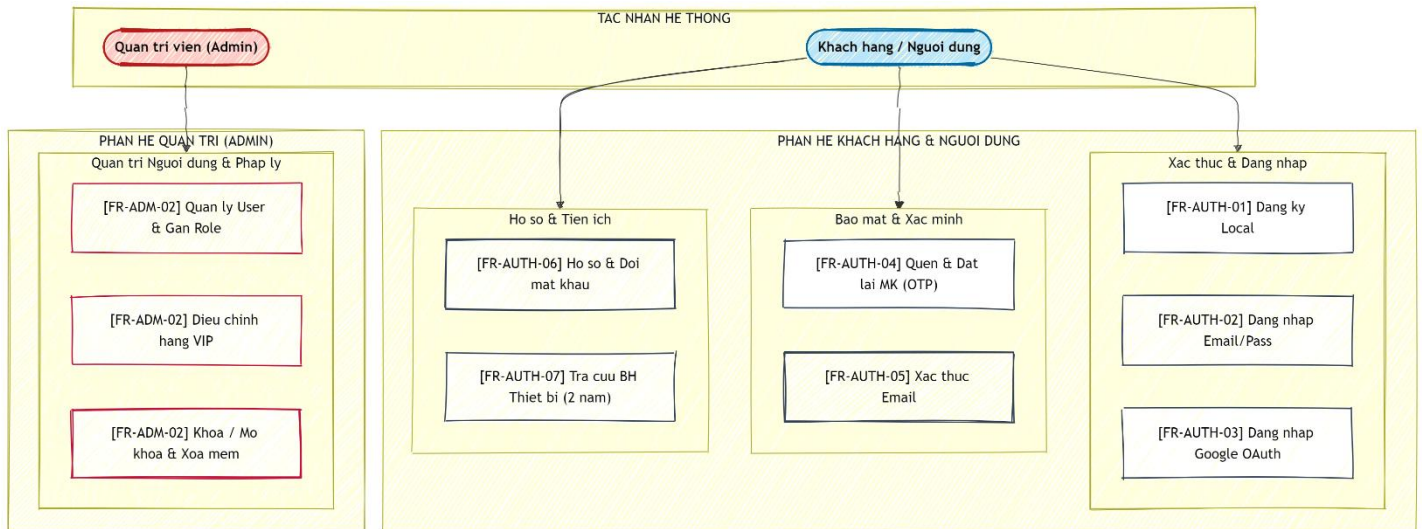
Mô tả: Cho phép người dùng đã đăng nhập xem danh sách sản phẩm thuộc các đơn hàng đã giao thành công.

Endpoint: GET /api/auth/my-devices.

- Backend sử dụng email trong JWT của người dùng hiện tại để truy vấn các đơn hàng có status_type: "success".
- Với mỗi sản phẩm trong các đơn hàng phù hợp, hệ thống trả về mã sản phẩm, tên sản phẩm, giá mua, ngày mua, ngày hết hạn bảo hành, thông số kỹ thuật và hình ảnh nếu có.
- Thời hạn bảo hành được tính mặc định là 2 năm kể từ ngày mua.

Quyền truy cập: JWT Logged In.

3.2. Phân hệ Danh mục & Quản lý Sản phẩm (Catalog & Product Management)



Hình 3. Sơ đồ chức năng phân hệ Sản phẩm và Danh mục

3.2.1. FR-PROD-01: Truy vấn Danh sách Sản phẩm (Get Products & Filtering)

Mô tả: Cung cấp danh sách sản phẩm phục vụ hiển thị trên trang chủ, trang sản phẩm và chức năng tìm kiếm của hệ thống.

Xử lý tại Backend:

- Endpoint GET /api/products trả về danh sách sản phẩm từ MongoDB.
- Mặc định Backend loại bỏ các sản phẩm có isDeleted: true.
- Backend đồng thời không trả về các sản phẩm thuộc danh mục có isDeleted: true.
- Query parameter search cho phép tìm kiếm không phân biệt chữ hoa/chữ thường trên các trường name, description và category.
- Khi có tham số search, Backend đồng thời ghi nhận từ khóa phục vụ Search History và Popular Search.
- Query parameter includeDeleted=true cho phép lấy cả sản phẩm đã xóa meme; khi sử dụng chế độ này, điều kiện ẩn sản phẩm theo isDeleted và danh mục bị vô hiệu hóa không được áp dụng.

Xử lý tại Frontend:

- Lọc sản phẩm theo danh mục.
- Tìm kiếm theo tên, mô tả, danh mục và thông số kỹ thuật hiển thị.
- Lọc theo khoảng giá.
- Lọc theo màu sắc.
- Sắp xếp theo giá tăng dần hoặc giảm dần.
- Phân trang với 12 sản phẩm trên mỗi trang.

Endpoint: GET /api/products.

Quyền truy cập: Public.

3.2.2. FR-PROD-02: Thêm mới Sản phẩm (Create Product - Admin Only)

Mô tả: Cho phép Admin tạo sản phẩm mới, khai báo thông tin sản phẩm và tải hình ảnh đại diện lên dịch vụ lưu trữ hình ảnh.

Ràng buộc & Xử lý:

- Các trường bắt buộc gồm name, price và category.
- price phải là giá trị số lớn hơn hoặc bằng 0.
- stock, nếu được khai báo, phải có giá trị lớn hơn hoặc bằng 0 theo schema Product; nếu không khai báo thì mặc định bằng 0.
- Backend tự động sinh _id từ name theo dạng slug.
- Nếu _id đã tồn tại, Backend tự động bổ sung hậu tố số để tạo mã sản phẩm duy nhất.
- Nếu Admin tải hình ảnh lên, Backend tiếp nhận tệp thông qua Multer.
- Hệ thống ưu tiên tải hình ảnh lên ImageKit. Nếu ImageKit không khả dụng hoặc quá trình upload thất bại, Backend tự động chuyển sang Cloudinary làm dịch vụ dự phòng.
- Nếu request không tải file nhưng có trường image, Backend có thể sử dụng trực tiếp URL ảnh được cung cấp.
- specs có thể được nhận dưới dạng JSON hoặc chuỗi JSON và được chuyển đổi trước khi lưu.

- colors có thể được nhận dưới dạng mảng hoặc chuỗi JSON và được chuyển đổi trước khi lưu.
- Nếu specs hoặc colors không thể parse hợp lệ, Backend sử dụng mảng rỗng.
- Khi tạo mới, sản phẩm mặc định có status: "AVAILABLE", badge: "NORMAL", stock: 0 nếu không được cung cấp và isDeleted: false.

Endpoint: POST /api/products.

Quyền truy cập: Admin.

3.2.3. FR-PROD-03: Cập nhật & Xóa Sản phẩm (Update, Soft Delete & Restore - Admin Only)

Mô tả: Cho phép Admin cập nhật thông tin sản phẩm, xóa mềm và khôi phục sản phẩm.

Cập nhật sản phẩm:

- Admin có thể cập nhật name, price, stock, category, description, specs, colors, badge và hình ảnh.
- Các trường chỉ được cập nhật khi được cung cấp trong request.
- price và stock được chuyển sang kiểu Number trước khi lưu.
- specs và colors hỗ trợ dữ liệu JSON hoặc chuỗi JSON.
- Nếu request có tệp ảnh mới, Backend sử dụng cơ chế upload ImageKit Primary → Cloudinary Fallback.
- Nếu ảnh cũ là tài nguyên Cloudinary và Backend xác định được public_id, hệ thống cố gắng xóa tài nguyên Cloudinary cũ trước khi cập nhật ảnh mới.
- Nếu request cung cấp trực tiếp trường image, Backend cập nhật URL ảnh theo giá trị được gửi.

Soft Delete:

- DELETE /api/products/:id không xóa vật lý bản ghi khỏi MongoDB.
- Backend cập nhật:

isDeleted = true

status = "DISCONTINUED"

- Sản phẩm đã xóa mềm không xuất hiện trong danh sách sản phẩm công khai mặc định.

Khôi phục:

- Khi khôi phục sản phẩm, Backend cập nhật:

isDeleted = false

status = "AVAILABLE"

- Hệ thống hỗ trợ cả hai endpoint khôi phục:

PATCH /api/products/:id/restore

PUT /api/products/:id/restore

Endpoints:

- PUT /api/products/:id – Cập nhật sản phẩm.
- DELETE /api/products/:id – Xóa mềm sản phẩm.
- PATCH /api/products/:id/restore – Khôi phục sản phẩm.
- PUT /api/products/:id/restore – Endpoint tương thích để khôi phục sản phẩm.

Quyền truy cập: Admin.

3.2.4. FR-CAT-01: Truy vấn Danh sách Danh mục

Mô tả: Cho phép lấy danh sách danh mục sản phẩm trong hệ thống.

- Mặc định GET /api/categories chỉ trả về các danh mục có isDeleted != true.
- Danh sách được sắp xếp theo created_at tăng dần.
- Query parameter includeDeleted=true cho phép lấy cả các danh mục đã bị xóa mềm/vô hiệu hóa.

Endpoint: GET /api/categories.

Quyền truy cập: Public.

3.2.5. FR-CAT-02: Tạo & Cập nhật Danh mục (Create & Update Category - Admin Only)

Mô tả: Cho phép Admin tạo danh mục mới hoặc thay đổi tên danh mục hiện có.

Ràng buộc:

- name là trường bắt buộc và không được để trống sau khi loại bỏ khoảng trắng đầu/cuối.
- Hệ thống kiểm tra tên danh mục trùng lặp không phân biệt chữ hoa/chữ thường.
- Khi tạo danh mục mới, nếu tìm thấy danh mục cùng tên đang có isDeleted: true, Backend không tạo bản ghi mới mà khôi phục danh mục cũ bằng cách đặt isDeleted: false.
- Nếu danh mục cùng tên đang hoạt động đã tồn tại, hệ thống từ chối tạo mới.
- Khi cập nhật, hệ thống không cho phép đổi tên thành tên của một danh mục khác đã tồn tại.

Endpoints:

- POST /api/categories – Tạo danh mục.
- PUT /api/categories/:id – Cập nhật danh mục.

Quyền truy cập: Admin.

3.2.6. FR-CAT-03: Vô hiệu hóa, Khôi phục & Xóa Danh mục (Category Lifecycle - Admin Only)

Mô tả: Cho phép Admin quản lý vòng đời của danh mục. Model Category hiện sử dụng trường Boolean isDeleted để biểu diễn trạng thái hiển thị/đã vô hiệu hóa; không có trường isActive riêng.

Xóa mềm: DELETE /api/categories/:id

cập nhật: isDeleted = true

Khôi phục: PATCH /api/categories/:id/restore

cập nhật: isDeleted = false

Bật/Tắt nhanh: PATCH /api/categories/:id/toggle

đảo giá trị hiện tại: isDeleted = !isDeleted

Xóa vĩnh viễn:

DELETE /api/categories/:id/permanent

xóa bản ghi Category khỏi MongoDB.

- Khi Category có isDeleted: true, Backend Product mặc định không trả về các sản phẩm thuộc Category đó trong GET /api/products.
- Các thao tác trên yêu cầu Category phải tồn tại; nếu không tìm thấy hệ thống trả HTTP 404.

Quyền truy cập: Admin.

3.3. Phân hệ Tìm kiếm & Phân tích Từ khóa (Search & Analytics)

3.3.1. FR-SRCH-01: Tìm kiếm Sản phẩm Thời gian Thực (Real-time Product Search)

Mô tả: Cho phép người dùng tìm kiếm nhanh sản phẩm thông qua Search Side Panel trên giao diện.

Luồng xử lý:

- Người dùng nhập từ khóa tìm kiếm trên giao diện.
- Frontend áp dụng cơ chế debounce 300 ms nhằm hạn chế gửi yêu cầu liên tục khi người dùng đang nhập.
- Nếu từ khóa rỗng hoặc chỉ chứa khoảng trắng, Frontend không gửi yêu cầu tìm kiếm và xóa danh sách kết quả hiện tại.
- Frontend gửi yêu cầu GET /api/products?search=<keyword> tới Backend.
- Backend chuẩn hóa từ khóa bằng cách loại bỏ khoảng trắng đầu/cuối.
- Backend thực hiện tìm kiếm không phân biệt chữ hoa/chữ thường trên các trường name, description và category.

- Mặc định hệ thống không trả về sản phẩm có isDeleted: true hoặc sản phẩm thuộc Category có isDeleted: true.
- Kết quả được hiển thị trực tiếp trên Search Side Panel.
- Người dùng có thể mở chi tiết sản phẩm hoặc thêm sản phẩm từ kết quả tìm kiếm vào giỏ hàng.
- Sau khi tìm kiếm thành công, Frontend tải lại Search History để phản ánh từ khóa vừa được ghi nhận.

Quyền truy cập: Public.

3.3.2. FR-SRCH-02: Ghi nhận Nhật ký Tìm kiếm (Search Logging)

Mô tả: Hệ thống ghi nhận từ khóa tìm kiếm nhằm phục vụ chức năng lịch sử tìm kiếm và thống kê từ khóa phổ biến.

Luồng xử lý:

- Khi Backend nhận GET /api/products có query parameter search, hệ thống cố gắng ghi nhận từ khóa vào collection SearchLog.
- Từ khóa được loại bỏ khoảng trắng đầu/cuối trước khi lưu.
- Nếu request có Authorization Header dạng Bearer <token> và JWT hợp lệ, Backend lấy id hoặc email trong token làm giá trị userId.
- Nếu request không có JWT hoặc JWT không hợp lệ/hết hạn, việc tìm kiếm vẫn được thực hiện và userId được lưu là null.
- Đối với Guest, hệ thống lưu thêm địa chỉ IP của request để hỗ trợ nhận diện lịch sử tìm kiếm.
- Thời điểm tìm kiếm được tự động ghi nhận trong created_at.
- Lỗi trong quá trình ghi SearchLog không làm thất bại yêu cầu tìm kiếm sản phẩm; hệ thống chỉ ghi log lỗi và tiếp tục trả kết quả tìm kiếm.

Dữ liệu SearchLog:

- query: từ khóa tìm kiếm
- userId: ID hoặc email người dùng nếu JWT hợp lệ; mặc định null
- ip: địa chỉ IP của request
- created_at: thời điểm tìm kiếm

3.3.3. FR-SRCH-03: Phân tích Từ khóa Phổ biến & Lịch sử Tìm kiếm (Popular & Recent Searches)

Mô tả: Cung cấp danh sách từ khóa tìm kiếm phổ biến trên toàn hệ thống và lịch sử tìm kiếm gần đây tương ứng với người dùng đã đăng nhập hoặc khách vãng lai.

Từ khóa tìm kiếm phổ biến:

- Endpoint: GET /api/search/popular.
- Backend nhóm các bản ghi SearchLog theo giá trị query không phân biệt chữ hoa/chữ thường.
- Hệ thống đếm số lần xuất hiện của mỗi từ khóa.
- Các nhóm được sắp xếp giảm dần theo số lượt tìm kiếm.
- Backend trả về tối đa 5 từ khóa phổ biến nhất.
- Giá trị hiển thị sử dụng một biểu diễn gốc của từ khóa trong nhóm.
- Nếu collection SearchLog chưa có dữ liệu, Backend trả về danh sách mặc định:
 - Laptop Pro
 - Ultra S26
 - Thủy tinh lỏng
 - Flux
 - Prism-1

nhằm tránh vùng Popular Search bị trống trên giao diện.

Lịch sử tìm kiếm gần đây:

- Endpoint: GET /api/search/history.
- JWT là tùy chọn.
- Nếu Authorization Header chứa JWT hợp lệ, Backend lấy id hoặc email trong token và truy vấn lịch sử theo userId.

- Nếu không có JWT hoặc JWT không hợp lệ, hệ thống xem request là Guest và truy vấn theo:
 - `userId = null`
 - `ip` = địa chỉ IP hiện tại
- Backend lấy tối đa 15 bản ghi gần nhất theo `created_at` giảm dần trước khi xử lý loại trùng.
- Các từ khóa trùng nhau không phân biệt chữ hoa/chữ thường được loại bỏ.
- Hệ thống trả tối đa 5 từ khóa gần nhất không trùng nhau.
- Nếu không có dữ liệu lịch sử:
 - User đã xác thực nhận danh sách mặc định: Core v2, TechVie Book.
 - Guest nhận danh sách mặc định: Laptop Pro, Ultra S26.

Xử lý tại Frontend:

- Khi Search Side Panel được mở, Frontend đồng thời gọi:
 - `GET /api/search/popular`
 - `GET /api/search/history`
- Nếu API Popular Search gặp lỗi kết nối, Frontend sử dụng một danh sách gợi ý mặc định cục bộ.
- Nếu API Search History gặp lỗi kết nối, Frontend sử dụng một danh sách lịch sử mặc định cục bộ.
- Khi người dùng thực hiện một lượt tìm kiếm thành công, Frontend gọi lại Search History để cập nhật danh sách gần nhất.

Quyền truy cập: Public; JWT là tùy chọn để cá nhân hóa Search History.

3.4. Phân hệ Giỏ hàng & Khuyến mãi (Cart & Voucher System)

3.4.1. FR-CART-01: Quản lý Giỏ hàng Trục tuyến (Client-side Cart Management)

Mô tả: Cho phép khách vãng lai và người dùng đã đăng nhập quản lý sản phẩm được chọn trước khi thực hiện Checkout.

Lưu trữ:

- Giỏ hàng được quản lý hoàn toàn tại Frontend và lưu trong LocalStorage với khóa `techvie_cart`.
- Khi ứng dụng khởi tạo, Frontend đọc dữ liệu từ `techvie_cart`; nếu dữ liệu không tồn tại hoặc không thể parse hợp lệ, hệ thống sử dụng giỏ hàng rỗng.
- Mỗi khi Cart thay đổi, Frontend tự động ghi lại toàn bộ Cart vào LocalStorage.

Các thao tác:

- Thêm sản phẩm vào Cart kèm `selectedColor` nếu có.
- Một Cart Item được xác định theo tổ hợp:
 - `product.id + selectedColor`
- Nếu cùng sản phẩm và cùng màu đã tồn tại, hệ thống tăng quantity thêm 1 thay vì tạo Cart Item mới.
- Nếu khác màu, cùng một sản phẩm có thể tồn tại thành nhiều Cart Item khác nhau.
- Người dùng có thể tăng hoặc giảm quantity.
- Khi quantity sau cập nhật nhỏ hơn hoặc bằng 0, Cart Item tương ứng được tự động loại bỏ.
- Người dùng có thể xóa riêng từng Cart Item hoặc xóa toàn bộ Cart.
- Người dùng có thể thay đổi màu của sản phẩm trực tiếp trong Cart Side Panel.
- Nếu đổi sang màu đã tồn tại đối với cùng sản phẩm, hệ thống gộp hai Cart Item và cộng quantity.
- Tổng số lượng được tính bằng tổng quantity của tất cả Cart Item.
- Tổng giá trị tạm tính được tính:
 - $subtotal = \Sigma(\text{product.price} \times \text{quantity})$
- Frontend Cart không giới hạn quantity trực tiếp theo stock; việc xác minh số lượng so với tồn kho được thực hiện tại bước Checkout phía Backend.

- Nút Checkout điều hướng người dùng sang trang Checkout chính.

Quyền truy cập: Public; không yêu cầu đăng nhập.

3.4.2. FR-VOCH-01: Áp dụng Mã Giảm giá (Apply Voucher)

Mô tả:

- Cho phép Guest hoặc User nhập mã Voucher tại Checkout để nhận ưu đãi khi đáp ứng điều kiện áp dụng.
- Khi mở Checkout, Frontend gọi GET /api/vouchers để lấy danh sách Voucher và có thể kết hợp với dữ liệu techvie_promos trong LocalStorage. Nếu không có dữ liệu, Frontend sử dụng một số Voucher mặc định phục vụ Demo.
- Mã Voucher được chuẩn hóa thành chữ in hoa trước khi kiểm tra.
- Voucher chỉ hợp lệ khi isActive = true và subtotal >= minOrderVal.
- Nếu discount > 1, Frontend chuẩn hóa về dạng tỷ lệ, ví dụ 10 → 0.1.
- Số tiền giảm được tính từ subtotal × discount; phí giao hàng là 0 với standard và 120000 VND với express.
- Tổng tiền cuối cùng được tính:

$$\text{finalTotal} = \text{subtotal} + \text{deliveryFee} - \text{discountAmount}$$

và không nhỏ hơn 0.

- Backend đồng thời cung cấp POST /api/vouchers/apply để kiểm tra code, isActive và minOrderVal; tuy nhiên Checkout Frontend hiện áp dụng Voucher trực tiếp trên dữ liệu đã tải.

Quyền truy cập: Public.

3.4.3. FR-VOCH-02: Quản lý Mã Giảm giá (Voucher Management)

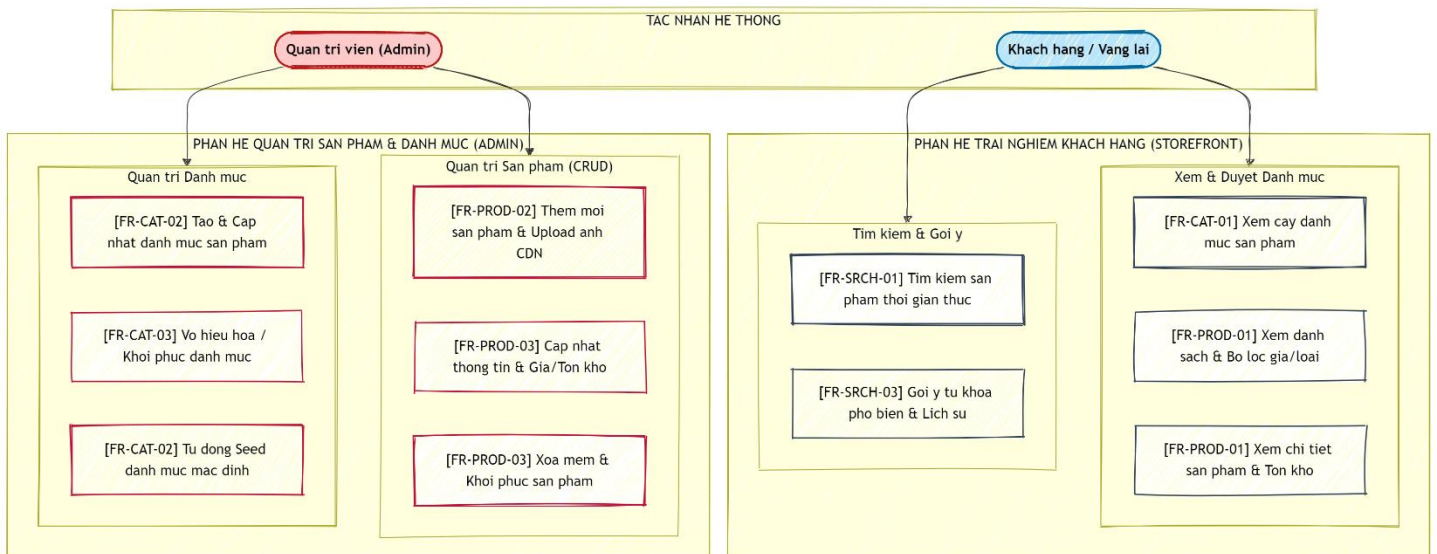
Mô tả: Hệ thống hỗ trợ xem, tạo, bật/tắt và xóa Voucher. Giao diện quản lý Voucher nằm trong Admin Dashboard.

Cấu trúc chính: code, discount, description, minOrderVal, usedCount, isActive, created_at.

Chức năng:

- GET /api/vouchers: Lấy danh sách Voucher, sắp xếp theo created_at giảm dần.
 - POST /api/vouchers: Tạo Voucher mới; code được chuẩn hóa chữ in hoa và không được trùng. Nếu discount > 1, Backend chuyển về dạng tỷ lệ, ví dụ 10 → 0.1.
 - PUT /api/vouchers/:id/toggle: Bật/tắt Voucher bằng cách đảo giá trị isActive.
 - DELETE /api/vouchers/:id: Xóa vật lý Voucher khỏi hệ thống.
 - POST /api/vouchers/apply: Kiểm tra Voucher theo code, isActive và minOrderVal.
- **Phân quyền hiện tại:** Giao diện quản lý chỉ dành cho Admin; tuy nhiên các route Voucher ở Backend hiện chưa áp dụng authMiddleware hoặc adminOnly, nên quyền Admin chưa được cường chế tại tầng API.

3.5. Phân hệ Đặt hàng & Thanh toán (Checkout, Gateways & Orders)



Hình 4. Sơ đồ quy trình Giỏ hàng, Đặt hàng và Thanh toán

3.5.1. FR-ORD-01: Quy trình Đặt hàng (Checkout Flow)

Mô tả: Cho phép Guest hoặc User tạo đơn hàng từ giỏ hàng thông qua POST /api/checkout.

Backend tiếp nhận thông tin giao nhận, Cart, phương thức vận chuyển, phương thức thanh toán và finalTotal từ Frontend. Hệ thống hỗ trợ cả camelCase và snake_case đối với một số trường.

Hệ thống kiểm tra:

- fullName/full_name, phone, email, address không được thiếu.
- Cart phải là mảng và có ít nhất một sản phẩm.
- quantity của mỗi sản phẩm phải là số nguyên và ≥ 1 .
- Nếu có Voucher Code, Voucher phải tồn tại và isActive = true.
- Nếu tìm thấy Product trong database, quantity không được vượt quá stock.

Phương thức thanh toán được lưu trong Order gồm:

- cod
- card_online
- bank_transfer
- momo
- zalopay

Phương thức giao hàng gồm standard và express.

Đơn hàng mới có:

- status_type = "processing"
- payment_status = "pending"

final_total được Backend nhận từ dữ liệu Checkout và lưu dưới dạng chuỗi tiền hiển thị.

Backend hiện không tự tính lại subtotal, deliveryFee hoặc discountAmount và không tự trừ stock sau khi tạo Order.

Endpoint: POST /api/checkout

Quyền truy cập: Public.

3.5.2. FR-ORD-02: Tích hợp Thanh toán & IPN Webhook (Payment Gateway Integration)

Mô tả: Hệ thống quản lý trạng thái thanh toán của Order và hỗ trợ đối soát chuyển khoản qua SePay.

Khi tạo đơn hàng, Backend sinh payment_reference dạng:

TECHVIE-XXXXXX

và tạo nội dung thanh toán tương ứng.

Người dùng có thể kiểm tra trạng thái thanh toán qua:

GET /api/checkout/payment/status/:orderId

SePay gửi giao dịch tới:

POST /api/checkout/payment/sepay-ipn

Backend kiểm tra Authorization Token của webhook, chỉ xử lý giao dịch transferType = "in", đọc mã TECHVIE-XXXXXX trong nội dung chuyển khoản và tìm Order theo payment_reference.

Số tiền nhận được phải lớn hơn hoặc bằng tổng tiền Order. Nếu hợp lệ:

- payment_status = "paid"
- transaction_id = mã giao dịch
- paid_at = thời điểm xác nhận

Nếu Order đã được xác nhận thanh toán trước đó, webhook trả thành công mà không cập nhật lại.

Hệ thống có endpoint:

POST /api/checkout/payment/sepay-ipn/simulate/:orderId

để giả lập SePay trong môi trường kiểm thử.

3.5.3. FR-ORD-03: Quản lý Đơn hàng (Order Lifecycle Management)

Mô tả: Cho phép người dùng đã đăng nhập theo dõi đơn hàng cá nhân và cho phép Admin quản lý, cập nhật trạng thái xử lý và trạng thái thanh toán của toàn bộ đơn hàng trong hệ thống.

Trạng thái xử lý đơn hàng (status_type):

- processing: Đơn hàng đang được tiếp nhận và xử lý.
- shipping: Đơn hàng đang được giao.
- success: Đơn hàng đã giao thành công.

- cancelled: Đơn hàng đã bị hủy.

Trạng thái thanh toán (payment_status):

- pending: Chưa thanh toán hoặc đang chờ xác nhận.
- paid: Đã thanh toán.
- failed: Thanh toán thất bại.
- cancelled: Thanh toán đã bị hủy.

Chức năng dành cho User:

- Người dùng đã đăng nhập xem lịch sử đơn hàng cá nhân thông qua GET /api/orders/user.
- Backend xác định đơn hàng của người dùng dựa trên email trong JWT và truy vấn các đơn hàng có email tương ứng.

Chức năng dành cho Admin:

- GET /api/orders: Xem toàn bộ đơn hàng.
- POST /api/orders/:id/status: Cập nhật trạng thái xử lý của đơn hàng.
- POST /api/orders/:id/payment-status: Cập nhật trạng thái thanh toán.
- DELETE /api/orders: Xóa toàn bộ đơn hàng theo chức năng quản trị hiện tại.

Khi trạng thái thanh toán được chuyển sang paid, Backend ghi nhận transaction_id và paid_at. Khi chuyển sang failed hoặc cancelled, Backend cập nhật thông tin thanh toán tương ứng.

Quyền truy cập:

User chỉ được xem đơn hàng cá nhân. Các chức năng quản trị toàn bộ đơn hàng hiện chỉ dành cho Admin.

3.6. Phân hệ Đánh giá & Nhận xét Sản phẩm (Reviews & Ratings)

3.6.1. FR-REV-01: Gửi Đánh giá Sản phẩm (Submit Product Review)

Mô tả: Cho phép User đã đăng nhập đánh giá sản phẩm đã mua và có đơn hàng giao thành công.

Điều kiện & xử lý:

- Backend kiểm tra Product phải tồn tại.
- Hệ thống xác định người dùng từ JWT và sử dụng email tài khoản để tìm Order có sản phẩm tương ứng với `status_type = "success"`.
- Có thể kiểm tra trước quyền đánh giá qua GET `/api/reviews/:productId/can-review`.
- `rating` là bắt buộc và phải nằm trong khoảng 1–5.
- `comment` là bắt buộc; `title` là tùy chọn.
- Mỗi User chỉ có một Review cho mỗi Product theo cặp `{product_id, user_id}`.
- Nếu Review cũ đã bị Soft Delete, khi người dùng đánh giá lại hệ thống khôi phục và cập nhật Review cũ thay vì tạo bản ghi mới.
- Review hợp lệ được lưu với `verified_purchase = true` và `order_id` của đơn hàng dùng để xác minh mua hàng.

Endpoints:

- GET `/api/reviews/:productId/can-review`
- POST `/api/reviews/:productId`

Quyền truy cập: Logged In – Verified Buyer.

3.6.2. FR-REV-02: Tự động Tính toán Điểm Đánh giá Trung bình (Rating Aggregation)

Mô tả: Hệ thống tự động cập nhật thống kê đánh giá của Product khi Review thay đổi.

- Khi Review được tạo, chỉnh sửa, Soft Delete hoặc khôi phục, hệ thống tính lại thống kê.
- Chỉ Review có `isDeleted != true` được sử dụng.
- `averageRating` được tính từ trung bình `rating` và làm tròn 1 chữ số thập phân.
- `reviewCount` là tổng số Review chưa bị xóa mềm.

- Nếu không còn Review:

averageRating = 0

reviewCount = 0

Lưu ý: isHidden = true không loại Review khỏi phép tính averageRating của Product; code hiện chỉ loại Review có isDeleted = true.

3.6.3. FR-REV-03: Quản lý & Kiểm duyệt Đánh giá (Review Management & Moderation)

Mô tả: Cho phép người dùng quản lý Review của mình và Admin thực hiện các chức năng kiểm duyệt Review toàn hệ thống.

Chức năng:

User – Chủ Review:

- PUT /api/reviews/:reviewId: Chỉnh sửa rating, title, comment của Review do chính mình tạo.
- DELETE /api/reviews/:reviewId: Soft Delete Review của chính mình.
- PATCH /api/reviews/:reviewId/toggle-hide: Ẩn hoặc hiện Review của chính mình.

Admin:

- GET /api/reviews/admin/all: Xem toàn bộ Review.
- GET /api/reviews/admin/stats: Xem thống kê Review.
- POST /api/reviews/admin/:reviewId/reply: Phản hồi Review.
- PATCH /api/reviews/:reviewId/restore: Khôi phục Review đã Soft Delete.
- Admin cũng có quyền Soft Delete và ẩn/hiện Review của người dùng.
- Review bị Soft Delete có: isDeleted = true
- Review bị ẩn có: isHidden = true
- Review ẩn không hiển thị cho người dùng khác, nhưng chủ Review và Admin vẫn có thể xem.

Quyền truy cập: Logged In đối với Review của chính mình; Admin đối với chức năng quản trị toàn hệ thống.

3.7. Phân hệ Hỗ trợ Khách hàng & Newsletter (Contact & Marketing)

3.7.1. FR-CNT-01: Gửi Thư Liên hệ (Contact Form)

Mô tả: Cho phép Guest hoặc User gửi yêu cầu tư vấn, góp ý hoặc phản hồi tới TechVie.

Thông tin bắt buộc:

- name: Họ tên người gửi.
- email: Email nhận phản hồi.
- subject: Chủ đề liên hệ.
- message: Nội dung liên hệ.

Luồng xử lý:

- Frontend kiểm tra cả 4 trường name, email, subject, message không được để trống.
- Backend tiếp tục kiểm tra cả 4 trường sau khi loại bỏ khoảng trắng đầu/cuối.
- Nếu thiếu bất kỳ trường nào, hệ thống từ chối yêu cầu với HTTP 400.
- Nếu hợp lệ, thông tin được lưu vào collection Contact cùng thời điểm created_at.
- Khi tạo thành công, Backend trả HTTP 201.

Endpoint: POST /api/contacts

Quyền truy cập: Public.

3.7.2. FR-CNT-02: Quản lý Thư Liên hệ & Trả lời qua Email

Mô tả: Cho phép Admin xem, trả lời và xóa các yêu cầu liên hệ của khách hàng.

Chức năng:

- GET /api/contacts: Lấy toàn bộ thư liên hệ, sắp xếp theo created_at mới nhất.
- POST /api/contacts/:id/reply: Gửi email phản hồi qua Nodemailer SMTP.
- replyContent là bắt buộc.
- replySubject là tùy chọn; nếu không cung cấp, Backend tạo tiêu đề dựa trên subject của thư gốc.
- DELETE /api/contacts/:id: Xóa vật lý thư liên hệ khỏi MongoDB.
- Nếu không tìm thấy Contact tương ứng, hệ thống trả HTTP 404.

Quyền truy cập: Admin Only.

3.7.3. FR-CNT-03: Đăng ký Nhận Bản tin (Newsletter Subscription)

Mô tả: Cho phép người dùng đăng ký nhận thông tin khuyến mãi và bản tin TechVie bằng email.

Luồng xử lý:

- Guest nhập email Newsletter; nếu User đã đăng nhập, Frontend có thể sử dụng email của tài khoản hiện tại.
- Frontend gửi POST /api/contacts với dữ liệu:

name = "Khách hàng đăng ký Newsletter"

email = email đăng ký

subject = "Đăng ký Nhận Bản Tin Khuyến Mãi"

message = nội dung yêu cầu đăng ký
- Khi Backend trả thành công, Frontend lưu:

techvie_subscribed = true

 trong LocalStorage và hiển thị thông báo đăng ký thành công.
- Nếu API Newsletter không kết nối được, Frontend hiện có cơ chế fallback offline và vẫn trả thông báo đăng ký thành công ở phía giao diện.

Endpoint: POST /api/contacts

Quyền truy cập: Public.

3.8. Phân hệ Quản trị & Báo cáo Vận hành (Admin Management & Dashboard)

3.8.1. FR-ADM-01: Bảng Điều khiển Tổng quan (Admin Dashboard Metrics)

Mô tả: Cho phép Admin theo dõi nhanh tình trạng vận hành của hệ thống thông qua Dashboard.

Các chỉ số chính:

- Doanh thu ước tính: Tổng finalTotal của các đơn hàng không có trạng thái "Hủy bỏ".
- Đơn hàng: Hiển thị tổng số đơn và số đơn có statusType = "processing".
- Sản phẩm: Hiển thị tổng số sản phẩm hiện có.
- Thư liên hệ: Hiển thị tổng số Contact đã tải từ Backend.
- Tồn kho: Tổng stock của toàn bộ sản phẩm.
- Cảnh báo tồn kho thấp: Sản phẩm có:

$$1 \leq \text{stock} \leq 5$$

được xác định là sắp hết hàng. Sản phẩm có stock = 0 được xếp vào nhóm hết hàng.

- Admin có thể truy cập các khu vực quản lý sản phẩm, tồn kho, đơn hàng, thanh toán, thư liên hệ, Voucher, người dùng và Review.

Quyền truy cập: Admin Only.

3.8.2. FR-ADM-02: Quản lý Thành viên & Phân quyền (User Administration & RBAC)

Mô tả: Cho phép Admin quản lý tài khoản, vai trò, trạng thái VIP, trạng thái hoạt động và Soft Delete người dùng.

Chức năng:

- Xem danh sách người dùng, bao gồm tài khoản đã Soft Delete khi cần.
- Tạo tài khoản mới; mật khẩu mặc định là 123456 và được bấm trước khi lưu.

- Thay đổi vai trò giữa user, employee, admin.
- Chuyển đổi vipStatus giữa Normal và Premium.
- Khóa/mở khóa tài khoản qua trạng thái active và blocked.
- Soft Delete tài khoản bằng isDeleted = true, đồng thời chuyển status = "blocked".
- Khôi phục tài khoản bằng isDeleted = false và status = "active".
- Admin không được tự đổi role, tự khóa hoặc tự xóa tài khoản của chính mình.

Phân quyền: employee hiện chỉ là vai trò được lưu trong hệ thống, chưa có Dashboard hoặc quyền quản trị riêng.

Quyền truy cập: Admin Only.

CHƯƠNG 4: YÊU CẦU GIAO DIỆN VÀ TÍCH HỢP (INTERFACE REQUIREMENTS)

4.1. Giao diện Người dùng (User Interface Specification)

- **Phong cách thiết kế:** Giao diện TechVie được thiết kế theo phong cách hiện đại, tối giản, sử dụng các thành phần Glassmorphism kết hợp hiệu ứng Neon/Cyber phù hợp với nhận diện thương hiệu công nghệ.
- **Responsive Design:** Giao diện phải tự động thích ứng với các kích thước màn hình phổ biến trên điện thoại, máy tính bảng và máy tính để bàn. Nội dung không được tràn khỏi màn hình, các thành phần điều hướng, biểu mẫu, bảng dữ liệu và thẻ sản phẩm phải duy trì khả năng sử dụng ở các kích thước màn hình được hỗ trợ.
- **Điều hướng:** Header, menu, Search Side Panel, Cart Side Panel và các thành phần điều hướng phải được hiển thị nhất quán giữa các trang.
- **Phản hồi thao tác:** Các thao tác như đăng nhập, thêm sản phẩm vào giỏ hàng, đặt hàng, gửi đánh giá và thao tác quản trị phải hiển thị thông báo thành công hoặc thất bại rõ ràng cho người dùng.
- **Animation:** Hệ thống có thể sử dụng các hiệu ứng chuyển động như chuyển trang, mở/đóng Side Panel, hover sản phẩm và Toast Notification nhằm cải thiện trải nghiệm người dùng nhưng không được ảnh hưởng đáng kể đến khả năng thao tác.

- **Biểu mẫu:** Các trường nhập liệu phải có nhãn hoặc placeholder rõ ràng và hiển thị thông báo khi dữ liệu không hợp lệ hoặc thiếu thông tin bắt buộc.
- **Trạng thái giao diện:** Hệ thống phải có giao diện phù hợp cho các trạng thái Loading, Empty Data, Success và Error.

4.2. Danh mục API Endpoints Chi tiết

4.2.1. Auth

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
POST	/api/auth/register	Public	Đăng ký tài khoản mới
POST	/api/auth/login	Public	Đăng nhập tài khoản
GET	/api/auth/check-email	Public	Kiểm tra email đã được sử dụng
GET	/api/auth/google	Public	Khởi tạo luồng Google OAuth
GET	/api/auth/profile	Logged In	Lấy thông tin hồ sơ tài khoản hiện tại
POST	/api/auth/forgot-password	Public	Gửi email chứa link đổi mật khẩu
POST	/api/auth/reset-password/:token	Public	Đặt lại mật khẩu mới bằng Token
GET	/api/auth/google/callback	Public	Xử lý callback Google OAuth
PUT	/api/auth/profile	Logged In	Cập nhật hồ sơ cá nhân
POST	/api/auth/change-password	Logged In	Đổi mật khẩu
POST	/api/auth/send-verification-email	Logged In	Gửi email xác thực
GET	/api/auth/verify-email	Public	Xác thực email bằng token
GET	/api/auth/my-devices	Logged In	Xem thiết bị đã mua & bảo hành

4.2.2. Product

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/products	Public	Lấy danh sách sản phẩm & lọc
POST	/api/products	Admin	Tạo sản phẩm, hỗ trợ upload ảnh
PUT	/api/products/:id	Admin	Cập nhật thông tin sản phẩm
DELETE	/api/products/:id	Admin	Xóa mềm sản phẩm
PATCH	/api/products/:id/restore	Admin	Khôi phục sản phẩm đã bị xóa
PUT	/api/products/:id/restore	Admin	Endpoint tương thích để khôi phục sản phẩm

4.2.3. Category

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/categories	Public	Lấy danh sách danh mục
POST	/api/categories	Admin	Thêm danh mục mới
PUT	/api/categories/:id	Admin	Cập nhật danh mục
DELETE	/api/categories/:id	Admin	Xóa mềm danh mục
PATCH	/api/categories/:id/restore	Admin	Khôi phục danh mục
PATCH	/api/categories/:id/toggle	Admin	Bật/Tắt danh mục
DELETE	/api/categories/:id/permanent	Admin	Xóa vĩnh viễn danh mục

4.2.4. Order & Checkout

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
--------	---------------	----------------	-----------------

POST	/api/checkout	Public	Tạo đơn đặt hàng mới
GET	/api/checkout/payment/status/:orderId	Public	Kiểm tra trạng thái thanh toán
POST	/api/checkout/payment/sepay-ipn	Public/Webhook	Nhận IPN từ SePay
POST	/api/checkout/payment/sepay-ipn/simulate/:orderId	Test/Developer	Giả lập SePay IPN
GET	/api/orders/user	Logged In	Xem đơn hàng cá nhân
GET	/api/orders	Admin	Xem toàn bộ đơn hàng
POST	/api/orders/:id/status	Admin	Cập nhật trạng thái đơn hàng
POST	/api/orders/:id/payment-status	Admin	Cập nhật trạng thái thanh toán
DELETE	/api/orders	Admin	Xóa toàn bộ đơn hàng

4.2.5. Review

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/reviews/:productId	Public	Xem Review sản phẩm
GET	/api/reviews/:productId/can-review	Logged In	Kiểm tra quyền Review
POST	/api/reviews/:productId	Logged In / Verified Buyer	Tạo Review
PUT	/api/reviews/:reviewId	Owner	Chỉnh sửa Review
DELETE	/api/reviews/:reviewId	Owner / Admin	Soft Delete Review
PATCH	/api/reviews/:reviewId/toggle-hide	Owner / Admin	Ẩn/Hiện đánh giá

PATCH	/api/reviews/:reviewId/restore	Admin	Khôi phục Review
GET	/api/reviews/admin/all	Admin	Xem toàn bộ Review
GET	/api/reviews/admin/stats	Admin	Xem thống kê Review
POST	/api/reviews/admin/:reviewId/reply	Admin	Phản hồi Review

4.2.6. User

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/users	Admin	Lấy danh sách người dùng
POST	/api/users	Admin	Tạo tài khoản
PUT	/api/users/:id/role	Admin	Thay đổi role
PUT	/api/users/:id/vip	Admin	Chuyển trạng thái VIP
PUT	/api/users/:id/status	Admin	Khóa/Mở khóa tài khoản
DELETE	/api/users/:id	Admin	Soft Delete tài khoản
PATCH	/api/users/:id/restore	Admin	Khôi phục tài khoản

4.2.7. Contact

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
POST	/api/contacts	Public	Gửi liên hệ / Newsletter
POST	/api/contacts/:id/reply	Admin	Trả lời liên hệ qua SMTP Email
GET	/api/contacts	Admin	Xem danh sách liên hệ
DELETE	/api/contacts/:id	Admin	Xóa thư liên hệ

4.2.8. Voucher

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/vouchers	Public	Lấy danh sách mã giảm giá
POST	/api/vouchers	Public*	Tạo mã giảm giá mới
POST	/api/vouchers/apply	Public	Kiểm tra/áp dụng Voucher
PUT	/api/vouchers/:id/toggle	Public*	Bật/Tắt Voucher
DELETE	/api/vouchers/:id	Public*	Xóa Voucher

(*) Giao diện quản lý Voucher chỉ dành cho Admin, nhưng các endpoint Backend tạo, bật/tắt và xóa Voucher hiện chưa áp dụng JWT Authentication hoặc adminOnly.

4.2.9. Search

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/search/popular	Public	Lấy tối đa 5 từ khóa phổ biến
GET	/api/search/history	Public / Optional JWT	Lấy tối đa 5 từ khóa gần đây

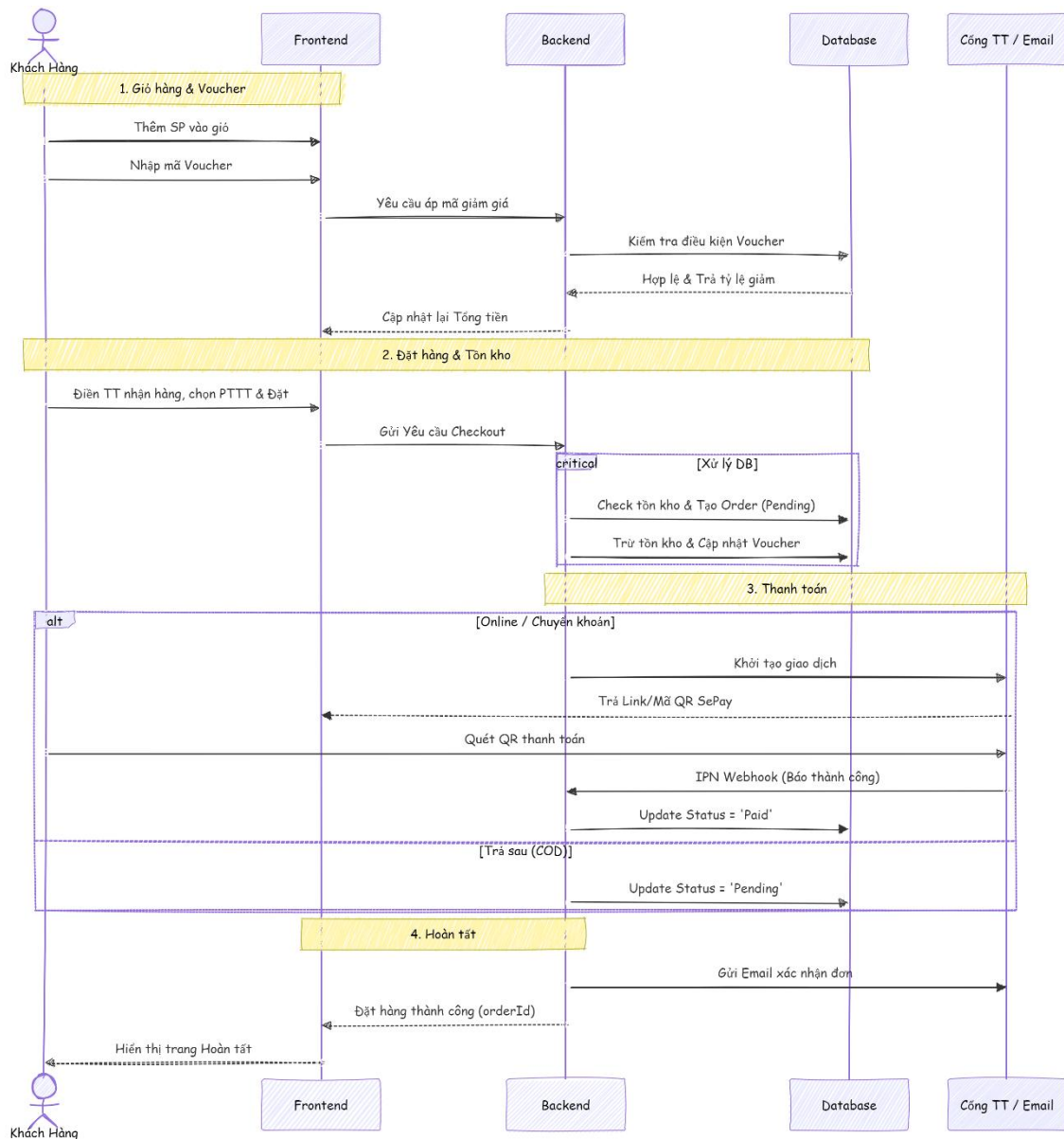
4.3. Tích hợp Dịch vụ Bên thứ 3 (External Interfaces)

Hệ thống TechVie tích hợp các dịch vụ bên ngoài để hỗ trợ lưu trữ hình ảnh, xác thực, gửi email và thanh toán.

- **ImageKit & Cloudinary – Lưu trữ hình ảnh:** Backend tiếp nhận ảnh thông qua Multer và ưu tiên upload lên ImageKit. Khi ImageKit không khả dụng hoặc upload thất bại, hệ thống sử dụng Cloudinary làm dịch vụ dự phòng. URL ảnh sau khi upload được lưu trong dữ liệu Product.
- **Google OAuth 2.0 – Xác thực Google:** Hệ thống hỗ trợ đăng nhập/đăng ký bằng Google thông qua Authorization Code. Backend lấy thông tin tài khoản Google, liên kết hoặc tạo tài khoản TechVie và phát hành JWT Token sau khi xác thực thành công.

- **Nodemailer SMTP – Dịch vụ Email:** Được sử dụng cho Email Verification, Reset Password và trả lời thư Contact.
- **SePay IPN – Đối soát chuyển khoản:** SePay gửi giao dịch đến POST /api/checkout/payment/sepay-ipn. Backend kiểm tra token webhook, mã payment_reference và số tiền nhận được; khi hợp lệ, Order được cập nhật payment_status = "paid", transaction_id và paid_at.
- **MoMo & ZaloPay:** Được hỗ trợ dưới dạng phương thức thanh toán trong môi trường Demo/Sandbox của hệ thống. Trạng thái thanh toán được lưu trong Order.
- **VNPAY:** Không được xem là phương thức thanh toán hoàn chỉnh trong phiên bản hiện tại do chưa đồng nhất với schema lưu trữ Order.

CHƯƠNG 5: YÊU CẦU PHI CHỨC NĂNG (NON-FUNCTIONAL REQUIREMENTS)



Hình 5. Quy trình giỏ hàng đặt hàng thanh toán

5.1. Hiệu năng & Khả năng Mở rộng (Performance & Scalability)

- **Thời gian phản hồi:** Hệ thống đặt mục tiêu ít nhất 95% yêu cầu đọc dữ liệu không vượt quá 200 ms và yêu cầu ghi dữ liệu không vượt quá 500 ms trong điều kiện bình thường, không tính độ trễ của dịch vụ bên thứ ba.
- **Khả năng mở rộng:** Kiến trúc Client–Server cho phép mở rộng Frontend, Backend và Database độc lập.
- **Khả năng chịu tải:** Hệ thống đặt mục tiêu hỗ trợ số lượng lớn người dùng đồng thời đối với các chức năng phổ biến như xem và tìm kiếm sản phẩm.

5.2. An toàn & Bảo mật Hệ thống (Security & Safety)

- **Mật khẩu:** Mật khẩu được băm bằng bcryptjs; luồng đăng ký sử dụng salt round = 10.
- **Token:** Reset Password Token và Email Verification Token có thời hạn và được băm SHA-256 trước khi lưu.
- **JWT Authentication:** Các API yêu cầu đăng nhập sử dụng JWT để xác định người dùng.
- **RBAC:** Các chức năng quản trị Product, Category, Order, User, Contact và các chức năng Admin khác được bảo vệ theo vai trò. Vai trò hệ thống gồm user, employee, admin.
- **Voucher:** Giao diện quản trị Voucher chỉ dành cho Admin; tuy nhiên các API quản lý Voucher ở Backend hiện chưa áp dụng authMiddleware hoặc adminOnly.
- **Tài khoản:** Tài khoản có status = "blocked" hoặc isDeleted = true không được phép đăng nhập bằng cơ chế thông thường.
- **Khôi phục mật khẩu:** Reset Password Token có hiệu lực 15 phút và bị xóa sau khi sử dụng thành công.
- **Email Verification:** Verification Token có hiệu lực 24 giờ.
- **HTTPS:** Trong môi trường Production, giao tiếp với Backend và các dịch vụ bên thứ ba được triển khai qua HTTPS khi nền tảng hỗ trợ.

5.3. Độ tin cậy & Khả năng Sẵn sàng (Reliability & Availability)

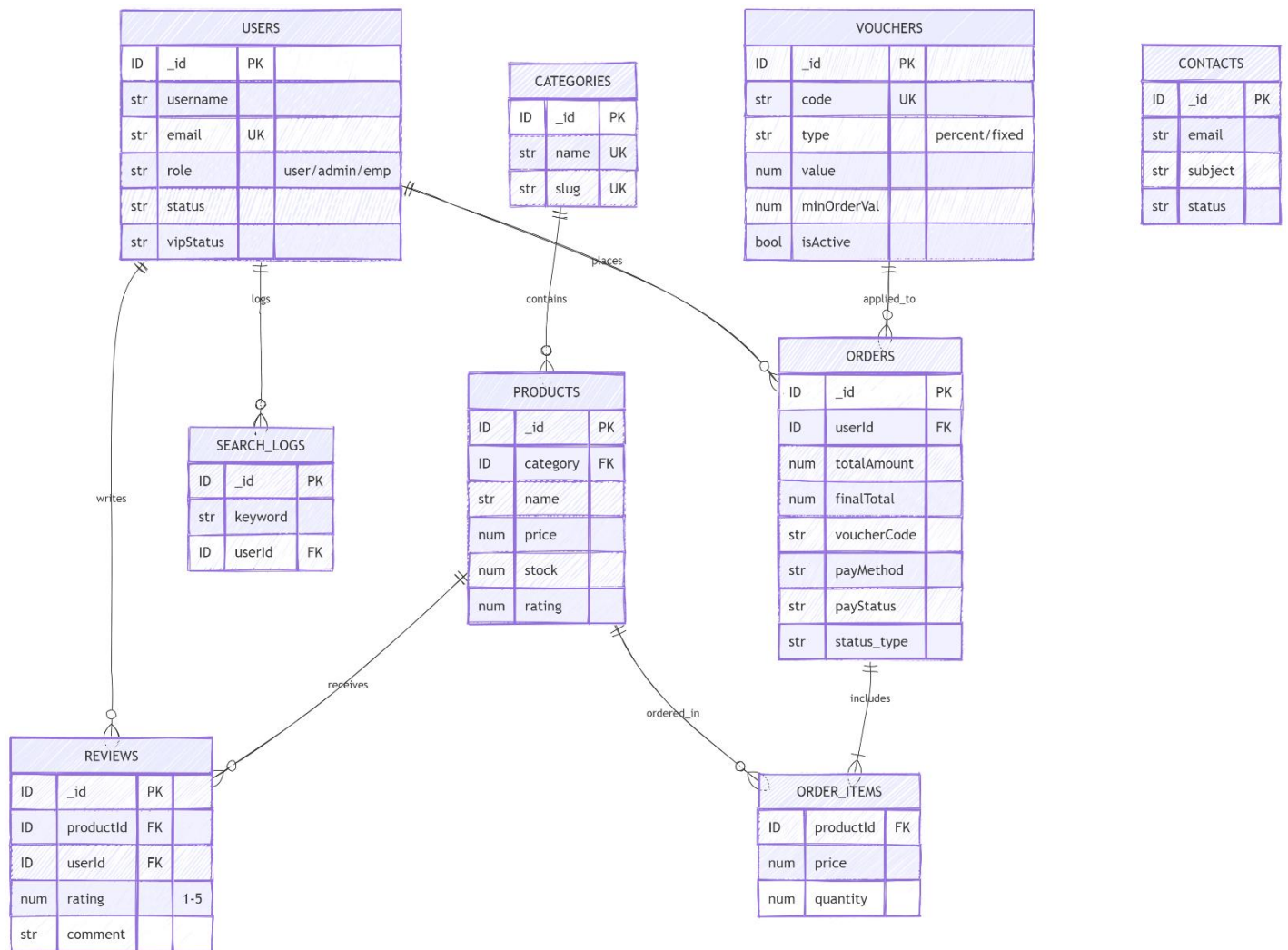
- **Tính sẵn sàng:** Hệ thống đặt mục tiêu duy trì khả năng truy cập ổn định trong môi trường Production, ngoại trừ thời gian bảo trì và sự cố từ dịch vụ bên thứ ba.
- **Xử lý lỗi:** Backend sử dụng HTTP Status Code và thông báo lỗi để phản hồi các request không hợp lệ hoặc khi xử lý thất bại.
- **Bảo toàn dữ liệu:** User, Product, Category và Review sử dụng Soft Delete ở các chức năng cần bảo lưu dữ liệu.
- **Thanh toán:** SePay IPN hỗ trợ cơ chế tránh cập nhật lại Order đã có payment_status = "paid".
- **Tồn kho:** Checkout hiện kiểm tra quantity không vượt stock khi tìm thấy Product, nhưng chưa tự động giảm hoặc hoàn trả stock khi Order được tạo/hủy.
- **Tổng tiền Order:** Backend hiện nhận finalTotal từ Frontend và chưa tự tính lại toàn bộ subtotal, phí giao hàng và giảm giá.

5.4. Trải nghiệm Người dùng (Usability & Accessibility)

- **Phản hồi thao tác:** Hệ thống phải hiển thị trạng thái Loading và thông báo thành công hoặc thất bại phù hợp cho các thao tác có xử lý bất đồng bộ.
- **Responsive Design:** Giao diện phải thích ứng với các kích thước màn hình phổ biến trên điện thoại, máy tính bảng và máy tính để bàn mà không làm mất các chức năng chính.
- **Khả năng tương thích:** Hệ thống phải hoạt động ổn định trên các trình duyệt web hiện đại như Google Chrome, Mozilla Firefox, Microsoft Edge và Apple Safari.
- **Tính nhất quán:** Các thành phần như nút, biểu mẫu, Header, Search Panel, Cart Panel và thông báo phải có cách trình bày và hành vi nhất quán giữa các trang.
- **Tính dễ sử dụng:** Các luồng nghiệp vụ chính như tìm sản phẩm, thêm vào giỏ, Checkout, đăng nhập và quản lý tài khoản phải được thiết kế rõ ràng, hạn chế các bước không cần thiết.

CHƯƠNG 6: ĐẶC TẢ CƠ SỞ DỮ LIỆU & SƠ ĐỒ HỆ THỐNG (DATABASE & SYSTEM MODELS)

6.1. Sơ đồ Thực thể Liên kết (ERD Diagram)



Hình 6. Sơ đồ Thực thể Liên kết (ERD) của hệ thống TechVic

6.2. Từ điển Dữ liệu Chi tiết (Data Dictionary / Schemas)

6.2.1. Collection users (Quản lý Tài khoản)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính
username	String	Có	-	Tên hiển thị người dùng
email	String	Có	-	Email duy nhất, lowercase
password	String	Có điều kiện	-	Bắt buộc khi auth_provider = "credentials"
phone	String	Không	""	Số điện thoại liên hệ
role	String	Không	"user"	user, employee, admin
vipStatus	String	Không	"Normal"	Normal, Premium
status	String	Không	"active"	Trạng thái tài khoản ("active" / "blocked")
auth_provider	String	Có	"credentials"	credentials, google
isEmailVerified	Boolean	Không	false	Xác nhận email đã xác thực
isDeleted	Boolean	Không	false	Cờ xóa mềm (Soft Delete)
created_at	Date	Không	Date.now	Thời điểm khởi tạo tài khoản
address	String	Không	-	Địa chỉ người dùng
google_id	String	Không	-	ID tài khoản Google đã liên kết
avatar	String	Không	-	URL ảnh đại diện
resetPasswordToken	String	Không	null	Bản băm SHA-256 của token đặt lại mật khẩu
resetPasswordExpire	Date	Không	null	Thời điểm hết hạn token đặt lại mật khẩu
emailVerificationToken	String	Không	null	Bản băm token xác thực email

emailVerificationExpire	Date	Không	null	Thời điểm hết hạn token xác thực email

6.2.2. Collection products (Danh mục Sản phẩm)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	String	Có	-	Mã sản phẩm dạng Slug
name	String	Có	-	Tên sản phẩm
category	String	Có	-	Tên danh mục sản phẩm
specs	Mixed	Không	[]	Thông số kỹ thuật của sản phẩm
colors	Array[String]	Không	[]	Danh sách màu sắc sản phẩm
price	Number	Có	-	Giá sản phẩm; schema min = 0; price ≥ 0
stock	Number	Không	0	Số lượng tồn kho khả dụng
image	String	Không	-	URL ảnh từ ImageKit, Cloudinary hoặc URL được cung cấp
description	String	Không	-	Mô tả chi tiết sản phẩm
created_at	Date	Tự động	Auto	Thời điểm tạo sản phẩm
updated_at	Date	Tự động	Auto	Thời điểm cập nhật
status	String	Không	"AVAILABLE"	Trạng thái kinh doanh ("AVAILABLE", "OUT_OF_STOCK", "DISCONTINUED")
badge	String	Không	"NORMAL"	Huy hiệu nổi bật ("PREMIUM",

				"TRENDY", "FLAGSHIP", "LIMITED", "NORMAL")
averageRating	Number	Không	0	Điểm trung bình 0–5
reviewCount	Number	Không	0	Tổng Review chưa Soft Delete
isDeleted	Boolean	Không	false	Cờ xóa mềm

6.2.3. Collection orders (Đơn hàng & Giao dịch)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	ID đơn hàng
full_name	String	Có	-	Họ tên người nhận
phone	String	Có	-	Số điện thoại
email	String	Có	-	Email đặt hàng
address	String	Có	-	Địa chỉ giao hàng
notes	String	Không	-	Ghi chú
payment_method	String	Có	-	cod, card_online, bank_transfer, momo, zalopay
payment_provider	String	Có	"cod"	Nhà cung cấp/phương thức thanh toán
payment_status	String	Có	"pending"	pending, paid, failed, cancelled
payment_reference	String	Không	-	Mã đối soát thanh toán

payment_note	String	Không	-	Nội dung hoặc ghi chú thanh toán
transaction_id	String	Không	-	Mã giao dịch
payment_url	String	Không	-	URL thanh toán MoMo/ZaloPay Demo hoặc Sandbox
paid_at	Date	Không	-	Thời điểm xác nhận thanh toán
delivery_method	String	Có	-	express, standard
final_total	String	Có	-	Chuỗi tổng tiền, ví dụ 350.000đ
status	String	Có	"Đang lắp ráp chuẩn bị gửi"	Nội dung trạng thái hiển thị
status_type	String	Có	"processing"	processing, shipping, success, cancelled
created_at	Date	Không	Date.now	Thời điểm tạo đơn
items	Array[OrderItem]	Không	[]	Danh sách sản phẩm

6.2.4. Collection reviews (Đánh giá Sản phẩm)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính
product_id	String (Ref)	Có	-	Mã sản phẩm được đánh giá
user_id	ObjectId (Ref)	Có	-	ID người dùng viết đánh giá

username	String	Có	-	Tên hiển thị người đánh giá
order_id	ObjectId (Ref)	Có	-	Mã đơn hàng xác minh đã mua
title	String	Không	-	Tiêu đề đánh giá, tối đa 100 ký tự
rating	Number	Có	-	Điểm đánh giá từ 1 đến 5
comment	String	Có	-	Nội dung đánh giá, tối đa 1000 ký tự
verified_purchase	Boolean	Không	true	Xác nhận người dùng đã mua sản phẩm
isHidden	Boolean	Không	false	Trạng thái ẩn Review
reply	Object	Không	-	Phản hồi gồm comment, replied_at, admin_username
isDeleted	Boolean	Không	false	Cờ Soft Delete
created_at	Date	Tự động	Auto	Thời điểm tạo Review
updated_at	Date	Tự động	Auto	Thời điểm cập nhật Review

6.2.5. Collection categories

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của danh mục

name	String	Có	-	Tên danh mục sản phẩm, không được để trống và phải duy nhất
isDeleted	Boolean	Không	false	Trạng thái xóa mềm/vô hiệu hóa danh mục
created_at	Date	Không	Date.now	Thời điểm tạo danh mục

6.2.6. Collection vouchers

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của Voucher
code	String	Có	-	Mã Voucher duy nhất, chuẩn hóa thành chữ in hoa
discount	Number	Có	-	Tỷ lệ giảm giá của Voucher
description	String	Không	""	Mô tả nội dung chương trình khuyến mãi
usedCount	Number	Không	0	Bộ đếm lượt sử dụng Voucher, mặc định 0; flow Apply Voucher hiện tại chưa tự động tăng giá trị này.
minOrderVal	Number	Không	0	Giá trị đơn hàng tối thiểu để được áp dụng Voucher
isActive	Boolean	Không	true	Trạng thái kích hoạt của Voucher
created_at	Date	Không	Date.now	Thời điểm tạo Voucher

6.2.7. Collection contacts

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của thư liên hệ
name	String	Có	-	Họ tên người gửi liên hệ
email	String	Có	-	Email của người gửi, dùng để nhận phản hồi
subject	String	Có	-	Chủ đề của yêu cầu liên hệ
message	String	Có	-	Nội dung yêu cầu, góp ý hoặc đăng ký Newsletter
created_at	Date	Không	Date.now	Thời điểm gửi yêu cầu liên hệ

6.2.8. Collection searchlogs

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của bản ghi tìm kiếm
query	String	Có	-	Từ khóa mà người dùng thực hiện tìm kiếm
userId	String / Null	Không	null	ID người dùng nếu request có JWT hợp lệ; để null đối với Guest
ip	String	Không	-	Địa chỉ IP của request, dùng nhận diện lịch sử của Guest
created_at	Date	Không	Date.now	Thời điểm thực hiện tìm kiếm

6.3. Ma trận Phân quyền Hệ thống (RBAC Matrix)

Chức năng / Quyền hạn	Guest	User	Employee	Admin
Xem danh sách & chi tiết sản phẩm	✓	✓	✓	✓
Tìm kiếm & lọc sản phẩm	✓	✓	✓	✓
Quản lý giỏ hàng & Checkout	✓	✓	✓	✓
Đăng ký tài khoản	✓	✓	✓	✓
Đăng nhập Local / Google	✓	✓	✓	✓
Quên & đặt lại mật khẩu	✓	✓*	✓*	✓*
Xác thực Email	X	✓	✓	✓
Quản lý hồ sơ & đổi mật khẩu	X	✓	✓	✓
Xem lịch sử đơn hàng cá nhân	X	✓	✓	✓
Tra cứu thiết bị đã mua & bảo hành	X	✓	✓	✓
Viết Review sản phẩm đã mua	X	✓*	✓*	✓*
Gửi Contact / đăng ký Newsletter	✓	✓	✓	✓
Quản lý Contact	X	X	X	✓
Quản lý Product	X	X	X	✓

Quản lý Category	X	X	X	✓
Quản lý toàn bộ Order	X	X	X	✓
Cập nhật trạng thái thanh toán Order	X	X	X	✓
Quản trị toàn bộ Review	X	X	X	✓
Chỉnh sửa / Xóa / Ẩn Review của chính mình	X	✓	✓	✓
Quản lý thành viên & phân quyền	X	X	X	✓
Truy cập Admin Dashboard	X	X	X	✓
Quản lý Voucher qua Admin UI	X	X	X	✓
Gọi trực tiếp API quản lý Voucher	✓**	✓**	✓**	✓

Ghi chú:

- ✓: Được phép thực hiện chức năng.
- X: Không được phép thực hiện chức năng.
- ✓*: Chức năng có điều kiện. Reset Password chỉ áp dụng cho tài khoản sử dụng phương thức credentials; Review chỉ được thực hiện khi đáp ứng điều kiện Verified Purchase.
- ✓**: API quản lý Voucher ở Backend hiện chưa áp dụng authMiddleware hoặc adminOnly; giao diện quản lý Voucher vẫn chỉ dành cho Admin.
- Vai trò employee hiện chưa có Dashboard hoặc quyền vận hành riêng.

CHƯƠNG 7: BẢNG KIỂM THỬ VÀ KỸ THUẬT THIẾT KẾ TEST (SOFTWARE TESTING ARTIFACTS)

7.1. Ma trận Truy xuất Yêu cầu (Requirements Traceability Matrix - RTM)

Mã Yêu Cầu (Req ID)	Tên Chức Năng	Kỹ Thuật Kiểm Thử Đề Xuất	Mã Kịch Bản Test (Test Scenario ID)
FR-AUTH-01	Đăng ký Tài khoản	Phân vùng tương đương (EP), Giá trị biên (BVA)	TS_AUTH_REG_01 → TS_AUTH_REG_04
FR-AUTH-02	Đăng nhập Hệ thống	Bảng quyết định, Kiểm thử An ninh (Security)	TS_AUTH_LGN_01 → TS_AUTH_LGN_04
FR-AUTH-03	Đăng nhập bằng Google OAuth 2.0	Kiểm thử Tích hợp, Security Testing	TS_AUTH_GOOGLE_01 → TS_AUTH_GOOGLE_04
FR-AUTH-04	Quên & Đặt lại Mật khẩu	EP, BVA, Security Testing	TS_AUTH_RESET_01 → TS_AUTH_RESET_06
FR-AUTH-05	Xác thực Email	Kiểm thử Tích hợp, Giá trị biên thời gian Token	TS_AUTH_VERIFY_01 → TS_AUTH_VERIFY_05
FR-AUTH-06	Quản lý Hồ sơ & Đổi Mật khẩu	Functional Testing, Security Testing	TS_AUTH_PROFILE_01 → TS_AUTH_PROFILE_05
FR-AUTH-07	Tra cứu Thiết bị đã mua & Bảo hành	Functional Testing, Authorization Testing	TS_AUTH_DEVICE_01 → TS_AUTH_DEVICE_04
FR-PROD-01	Truy vấn Danh sách, Lọc & Sắp xếp Sản phẩm	EP, Combinatorial Testing	TS_PRD_SRC_01 → TS_PRD_SRC_06
FR-PROD-02	Thêm mới Sản phẩm	EP, BVA, ImageKit/Cloudinary Integration Testing	TS_PRD_CREATE_01 → TS_PRD_CREATE_05
FR-PROD-03	Cập nhật, Xóa mềm & Khôi phục Sản phẩm	Functional Testing, State Transition Testing, ImageKit/Cloudinary Upload	TS_PRD_MGMT_01 → TS_PRD_MGMT_06

FR-CAT-01	Truy vấn Danh sách Danh mục	Functional Testing	TS_CAT_GET_01 → TS_CAT_GET_02
FR-CAT-02	Tạo & Cập nhật Danh mục	EP, Duplicate Validation	TS_CAT_CU_01 → TS_CAT_CU_04
FR-CAT-03	Vô hiệu hóa, Khôi phục & Xóa Danh mục	State Transition Testing, RBAC Testing	TS_CAT_STATE_01 → TS_CAT_STATE_05
FR-SRCH-01	Tìm kiếm Sản phẩm Thời gian Thực	EP, Functional Testing	TS_SRC_REALTIME_01 → TS_SRC_REALTIME_04
FR-SRCH-02	Ghi nhận Nhật ký Tìm kiếm	Integration Testing, Data Validation	TS_SRC_LOG_01 → TS_SRC_LOG_03
FR-SRCH-03	Từ khóa Phổ biến & Lịch sử Tìm kiếm	Functional Testing, Data Validation	TS_SRC_HISTORY_01 → TS_SRC_HISTORY_04
FR-CART-01	Quản lý Giỏ hàng	BVA, Functional Testing	TS_CRT_01 → TS_CRT_04
FR-VOCH-01	Áp dụng Mã Giảm giá	Decision Table Testing, BVA	TS_VOU_01 → TS_VOU_05
FR-VOCH-02	Quản lý Mã Giảm giá	Functional Testing, Security/RBAC Testing	TS_VOU_ADM_01 → TS_VOU_ADM_05
FR-ORD-01	Quy trình Đặt hàng (Checkout)	EP, BVA, Integration Testing	TS_CHK_01 → TS_CHK_08
FR-ORD-02	Tích hợp Thanh toán & SePay IPN Webhook	Integration Testing, Mock Webhook	TS_PAY_QR_01 → TS_PAY_QR_03
FR-ORD-03	Quản lý Vòng đời Đơn hàng	State Transition Testing, Authorization/RBAC Testing	TS_ORD_ST_01 → TS_ORD_ST_05
FR-REV-01	Gửi Đánh giá Verified Purchase	Integration Testing, Compound Index Validation	TS_REV_01 → TS_REV_04

FR-REV-02	Tính Điểm Đánh giá Trung bình	Data Validation, Functional Testing	TS_REV_RATE_01 → TS_REV_RATE_04
FR-REV-03	Quản trị Đánh giá	Functional Testing, RBAC Testing	TS_REV_ADM_01 → TS_REV_ADM_05
FR-CNT-01	Gửi Thư Liên hệ	EP, Input Validation	TS_CNT_SEND_01 → TS_CNT_SEND_04
FR-CNT-02	Quản lý & Trả lời Thư Liên hệ	Integration Testing, RBAC Testing	TS_CNT_ADM_01 → TS_CNT_ADM_05
FR-CNT-03	Đăng ký Nhận Bản tin Newsletter	Functional Testing, Input Validation	TS_CNT_NEWS_01 → TS_CNT_NEWS_03
FR-ADM-01	Bảng Điều khiển Tổng quan	Data Validation, Functional Testing	TS_ADM_DASH_01 → TS_ADM_DASH_05
FR-ADM-02	Quản lý Thành viên & Phân quyền	RBAC Testing, Functional Testing	TS_ADM_USR_01 → TS_ADM_USR_05

7.2. Bảng Chuyển Trạng Thái Đơn Hàng (State Transition Table)

Trạng thái hiện tại	Sự kiện / Hành động	Trạng thái tiếp theo (status_type)	Trạng thái thanh toán	Kết quả mong đợi
Khởi tạo	Khách Checkout bằng COD	processing	pending	Tạo Order thành công và lưu thông tin giao nhận, không tự động giảm stock
Khởi tạo	Khách Checkout bằng Bank Transfer / MoMo / ZaloPay	processing	pending	Tạo Order và sinh thông tin tham chiếu thanh toán
processing	SePay gửi IPN hợp lệ với số tiền >= tổng Order	processing	paid	Xác nhận thanh toán, lưu transaction_id và paid_at
processing	Admin cập nhật đơn sang trạng thái giao hàng	shipping	Giữ nguyên	Cập nhật status_type = shipping

shipping	Admin xác nhận giao hàng thành công	success	Giữ nguyên	Cập nhật status_type = success, trạng thái thanh toán không tự động thay đổi
processing / shipping	Admin cập nhật payment_status = paid	Giữ nguyên	paid	Ghi nhận transaction_id và paid_at
processing / shipping	Admin hủy đơn hàng	cancelled	Giữ nguyên	Cập nhật status_type = cancelled, không tự động hoàn stock
Bất kỳ	Admin gửi status_type ngoài các giá trị được schema hỗ trợ	Không cập nhật	Giữ nguyên	Yêu cầu lưu dữ liệu thất bại do status_type không hợp lệ

Ghi chú:

- status_type hỗ trợ: processing, shipping, success, cancelled.
- payment_status hỗ trợ: pending, paid, failed, cancelled.
- Các API cập nhật trạng thái Order hiện chỉ dành cho Admin; Employee chưa có quyền vận hành riêng.
- Trạng thái xử lý đơn hàng và trạng thái thanh toán được quản lý tương đối độc lập. Việc chuyển Order sang success không tự động chuyển payment_status sang paid.
- Checkout hiện kiểm tra quantity không vượt stock nhưng không tự giảm stock khi tạo Order và không tự hoàn stock khi hủy Order.
- SePay chấp nhận giao dịch khi transferAmount >= tổng tiền Order.
- Backend hiện chưa áp dụng quy tắc bắt buộc về thứ tự chuyển trạng thái; Admin có thể cập nhật sang một status_type hợp lệ trong enum mà không cần đi đúng chuỗi processing → shipping → success.

7.3. Bảng Quyết Định Kiểm Thử Mã Giảm Giá (Decision Table - Voucher)

Điều kiện / Hành động	Rule 1	Rule 2	Rule 3	Rule 4
Điều kiện				
Mã Voucher có tồn tại trong hệ thống?	K	C	C	C
Voucher có isActive: true?	-	K	C	C

subtotal >= minOrderVal?	-	-	K	C
Hành động				
Chấp nhận áp dụng Voucher	K	K	K	C
Tính discountAmount = subtotal × discount	K	K	K	C
Tính lại finalTotal = subtotal + deliveryFee - discountAmount	K	K	K	C
Hiển thị thông báo Voucher không tồn tại	C	K	K	K
Hiển thị thông báo Voucher đang tạm dừng	K	C	K	K
Hiển thị thông báo chưa đạt giá trị đơn hàng tối thiểu	K	K	C	K
Hiển thị thông báo áp dụng Voucher thành công	K	K	K	C
Ghi chú: C = Có/Đúng, K = Không/Sai, - = Không xét. Ý nghĩa 4 Rule: • Rule 1: Mã không tồn tại → từ chối. • Rule 2: Mã có tồn tại nhưng isActive = false → từ chối. • Rule 3: Voucher hoạt động nhưng đơn hàng chưa đạt minOrderVal → từ chối. • Rule 4: Tất cả điều kiện hợp lệ → áp dụng giảm giá.				

7.4. Môi Trường & Công Cụ Kiểm Thử Đề Xuất (Test Environment Setup)

7.4.1. Kiểm thử API & Tích hợp (API & Integration Testing):

Công cụ: Postman / Collection Runner / Newman.

Phạm vi: Kiểm thử các API /api/auth, /api/products, /api/categories, /api/search, /api/checkout, /api/orders, /api/reviews, /api/users, /api/contacts và /api/vouchers.

Nội dung kiểm thử:

- HTTP Method, Status Code và Response Body.
- Dữ liệu hợp lệ/không hợp lệ và các giá trị biên.

- JWT Authentication và phân quyền user, employee, admin.
- Kiểm tra API Public, Logged In và Admin Only.
- Xác minh Employee không truy cập được các chức năng Admin hiện tại.
- Kiểm thử Google OAuth, Email SMTP, Image Upload và SePay IPN.

7.4.2. Kiểm thử Giao diện & End-to-End (UI & E2E Testing):

Công cụ: Cypress, Playwright hoặc Selenium.

Các luồng ưu tiên:

- Đăng ký → Đăng nhập → Xác thực Email.
- Tìm kiếm → Thêm sản phẩm vào Cart → Checkout.
- Áp dụng Voucher → Chọn phương thức thanh toán → Tạo Order.
- Theo dõi Order → Review sản phẩm đã mua.
- Admin đăng nhập → quản lý Product, Order, User, Contact và Review.
- Employee đăng nhập → xác minh không thể truy cập /admin/*.
- Kiểm thử các giá trị biên trên giao diện như Cart Quantity và cảnh báo Stock.

7.4.3. Kiểm thử Hiệu năng (Performance & Load Testing):

Sử dụng Apache JMeter hoặc k6 để kiểm thử tải đối với các API có tần suất truy cập cao như danh sách sản phẩm, tìm kiếm sản phẩm và các API đọc dữ liệu. Theo dõi thời gian phản hồi, tỷ lệ lỗi và khả năng hoạt động khi có nhiều request đồng thời.

7.4.4. Kiểm thử Bảo mật (Security Testing):

Công cụ: OWASP ZAP kết hợp kiểm thử thủ công.

Nội dung:

- JWT Authentication.
- RBAC và truy cập trái phép API Admin.
- Xác minh Employee không có quyền Admin.

- Tài khoản blocked hoặc isDeleted không thể đăng nhập.
- Input Validation.
- XSS, Injection và Broken Object Level Authorization.
- Kiểm tra Reset Password Token và Email Verification Token hết hạn.
- Kiểm tra các API Voucher quản trị hiện chưa được Backend bảo vệ bằng adminOnly để ghi nhận rủi ro phân quyền.

7.4.5. Kiểm thử các Dịch vụ Bên thứ ba (External Service Testing)

Các tích hợp bên thứ ba được kiểm thử trong môi trường Test, Demo hoặc Sandbox; không sử dụng giao dịch tài chính thật trong kiểm thử chức năng thông thường.

- **ImageKit:** Kiểm thử upload hình ảnh chính.
- **Cloudinary:** Kiểm thử cơ chế upload dự phòng khi ImageKit không khả dụng.
- **Google OAuth 2.0:** Kiểm thử đăng nhập và liên kết tài khoản Google.
- **Nodemailer SMTP:** Kiểm thử Email Verification, Reset Password và Reply Contact.
- **SePay IPN:** Kiểm thử đối soát giao dịch và cập nhật payment_status.
- **MoMo / ZaloPay:** Kiểm thử các luồng Demo/Sandbox được hệ thống hỗ trợ.
- **VNPAY:** Không xem là tích hợp hoàn chỉnh trong phiên bản hiện tại và không đưa vào phạm vi kiểm thử thanh toán chính thức.

7.4.6. Chức năng hỗ trợ Demo/Test:

Các chức năng hỗ trợ Test/Demo chỉ được sử dụng trong môi trường kiểm thử và không được xem là API nghiệp vụ chính của hệ thống.

Hệ thống hỗ trợ các endpoint:

- POST /api/auth/test/set-reset-token-time
- Dùng để thiết lập tuổi của Reset Password Token nhằm kiểm thử các giá trị biên thời gian như 14m59s, 15m00s, 15m01s.

- POST /api/auth/test/set-verification-token-time
- Dùng để thiết lập tuổi của Email Verification Token nhằm kiểm thử các giá trị biên như 23h59m59s, 24h00m00s, 24h00m01s.

Các Test Route này chỉ được bật trong môi trường phù hợp; trong Production chúng không nên được công khai khi chức năng Test Route chưa được cho phép.

Chức năng Quick Switch Account, nếu có sử dụng, chỉ phục vụ chuyển nhanh giữa các tài khoản mẫu trong quá trình Demo/Test.

TỔNG KẾT TÀI LIỆU

Tài liệu SRS này quy định đầy đủ các tiêu chuẩn kỹ thuật, cấu trúc cơ sở dữ liệu, các sơ đồ hệ thống và quy trình nghiệp vụ của Hệ thống Website Thương mại Điện tử TechVie. Đội ngũ phát triển và kiểm thử có trách nhiệm tuân thủ nghiêm ngặt các quy định trong tài liệu này trong suốt quá trình vận hành và bảo trì sản phẩm.